



Threagile

Agile Threat Modeling

Threat Model Report

DigiLocker Threat Model

01 Aug 2026

Gunda Swetha, Sravani Avadurthi, Nikhil Kumar,
Amit Kumar Saini, Sudheer Kumar Thammana

Table of Contents

Results Overview

Management Summary	4
Impact Analysis of 74 Initial Risks in 20 Categories	5
Risk Mitigation	8
Impact Analysis of 74 Remaining Risks in 20 Categories	9
Application Overview	12
Data-Flow Diagram	13
Security Requirements	15
Abuse Cases	16
Tag Listing	17
STRIDE Classification of Identified Risks	18
Assignment by Function	21
RAA Analysis	24
Data Mapping	26
Out-of-Scope Assets: 0 Assets	27
Potential Model Failures: 7 / 7 Risks	28
Questions: 0 / 0 Questions	29

Risks by Vulnerability Category

Identified Risks by Vulnerability Category	30
SQL/NoSQL-Injection: 5 / 5 Risks	31
Cross-Site Request Forgery (CSRF): 4 / 4 Risks	33
Cross-Site Scripting (XSS): 5 / 5 Risks	35
Missing Cloud Hardening: 1 / 1 Risk	37
Missing Hardening: 3 / 3 Risks	40
Missing Identity Provider Isolation: 2 / 2 Risks	42
Server-Side Request Forgery (SSRF): 9 / 9 Risks	44
Unguarded Access From Internet: 4 / 4 Risks	47
Unguarded Direct Datastore Access: 5 / 5 Risks	49
Container Base Image Backdooring: 6 / 6 Risks	51
Missing Build Infrastructure: 1 / 1 Risk	53
Missing Identity Propagation: 3 / 3 Risks	55
Missing Identity Store: 1 / 1 Risk	57
Missing Network Segmentation: 1 / 1 Risk	59
Missing Two-Factor Authentication (2FA): 2 / 2 Risks	61
Missing Vault (Secret Storage): 1 / 1 Risk	63
Missing Web Application Firewall (WAF): 5 / 5 Risks	65
Unencrypted Technical Assets: 2 / 2 Risks	67

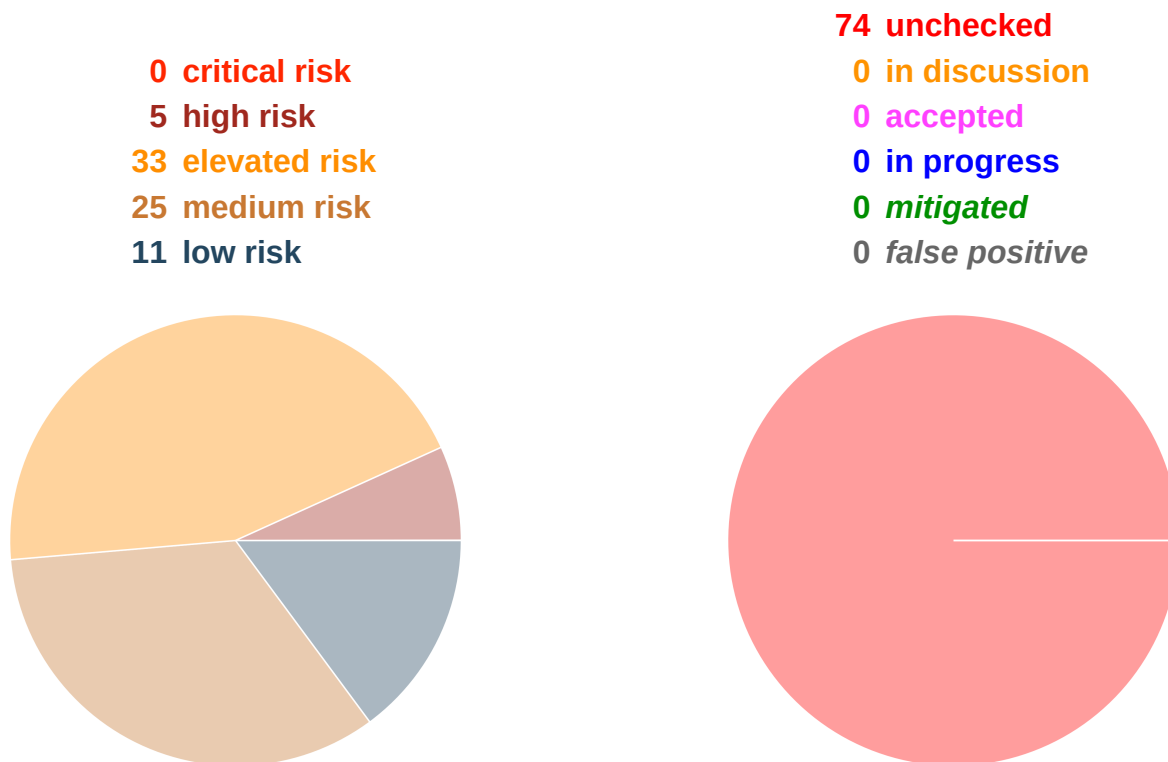
Unnecessary Data Transfer: 4 / 4 Risks	69
DoS-risky Access Across Trust-Boundary: 10 / 10 Risks	71
Risks by Technical Asset	
Identified Risks by Technical Asset	74
authentication-service: 13 / 13 Risks	75
consent-manager: 5 / 5 Risks	80
digilocker-backend: 16 / 16 Risks	83
monitoring-service: 2 / 2 Risks	90
api-gateway: 12 / 12 Risks	93
citizen-web-portal: 2 / 2 Risks	98
database: 10 / 10 Risks	100
document-repository: 3 / 3 Risks	104
identity-provider: 5 / 5 Risks	106
issuer-service: 2 / 2 Risks	109
notification-service: 1 / 1 Risk	111
requester-service: 2 / 2 Risks	113
mobile-app: 0 / 0 Risks	115
Data Breach Probabilities by Data Asset	
Identified Data Breach Probabilities by Data Asset	117
aadhaar-data: 19 / 19 Risks	118
audit-logs: 17 / 17 Risks	119
authentication-tokens: 44 / 44 Risks	120
citizen-profile: 37 / 37 Risks	122
consent-records: 27 / 27 Risks	124
issued-documents: 21 / 21 Risks	126
uploaded-documents: 16 / 16 Risks	127
digital-signatures: 3 / 3 Risks	128
Trust Boundaries	
Application Zone	129
Data Zone	129
DMZ	129
About Threagile	
Risk Rules Checked by Threagile	131
Disclaimer	144

Management Summary

Threagile toolkit was used to model the architecture of "DigiLocker Threat Model" and derive risks by analyzing the components and data flows. The risks identified during this analysis are shown in the following chapters. Identified risks during threat modeling do not necessarily mean that the vulnerability associated with this risk actually exists: it is more to be seen as a list of potential risks and threats, which should be individually reviewed and reduced by removing false positives. For the remaining risks it should be checked in the design and implementation of "DigiLocker Threat Model" whether the mitigation advices have been applied or not.

Each risk finding references a chapter of the OWASP ASVS (Application Security Verification Standard) audit checklist. The OWASP ASVS checklist should be considered as an inspiration by architects and developers to further harden the application in a Defense-in-Depth approach. Additionally, for each risk finding a link towards a matching OWASP Cheat Sheet or similar with technical details about how to implement a mitigation is given.

In total **74 initial risks** in **20 categories** have been identified during the threat modeling process:



Threat model prepared for DigiLocker architecture.

Impact Analysis of 74 Initial Risks in 20 Categories

The most prevalent impacts of the **74 initial risks** (distributed over **20 risk categories**) are (taking the severity ratings into account and using the highest for each category):

Risk finding paragraphs are clickable and link to the corresponding chapter.

High: [SQL/NoSQL-Injection](#): 5 Initial Risks - Exploitation likelihood is *Very Likely with High impact*. If this risk is unmitigated, attackers might be able to modify SQL/NoSQL queries to steal and modify data and eventually further escalate towards a deeper system penetration via code executions.

Elevated: [Cross-Site Request Forgery \(CSRF\)](#): 4 Initial Risks - Exploitation likelihood is *Very Likely with Medium impact*. If this risk remains unmitigated, attackers might be able to trick logged-in victim users into unwanted actions within the web application by visiting an attacker controlled web site.

Elevated: [Cross-Site Scripting \(XSS\)](#): 5 Initial Risks - Exploitation likelihood is *Likely with High impact*. If this risk remains unmitigated, attackers might be able to access individual victim sessions and steal or modify user data.

Elevated: [Missing Cloud Hardening](#): 1 Initial Risk - Exploitation likelihood is *Unlikely with Very High impact*. If this risk is unmitigated, attackers might access cloud components in an unintended way.

Elevated: [Missing Hardening](#): 3 Initial Risks - Exploitation likelihood is *Likely with Medium impact*. If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Elevated: [Missing Identity Provider Isolation](#): 2 Initial Risks - Exploitation likelihood is *Unlikely with Very High impact*. If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards highly sensitive identity provider assets and their identity datastores, as they are not separated by network segmentation.

Elevated: [Server-Side Request Forgery \(SSRF\)](#): 9 Initial Risks - Exploitation likelihood is *Likely with Medium impact*. If this risk is unmitigated, attackers might be able to access sensitive services or files of network-reachable components by modifying outgoing calls of affected components.

Elevated: [Unguarded Access From Internet](#): 4 Initial Risks - Exploitation likelihood is *Very Likely with Medium impact*. If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Elevated: [Unguarded Direct Datastore Access](#): 5 Initial Risks - Exploitation likelihood is *Likely with Medium impact*. If this risk is unmitigated, attackers might be able to directly attack sensitive datastores without any protecting components in-between.

Medium: Container Base Image Backdooring: 6 Initial Risks - Exploitation likelihood is *Unlikely* with *High* impact.

If this risk is unmitigated, attackers might be able to deeply persist in the target system by executing code in deployed containers.

Medium: Missing Build Infrastructure: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Medium: Missing Identity Propagation: 3 Initial Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to access or modify foreign data after a successful compromise of a component within the system due to missing resource-based authorization checks.

Medium: Missing Identity Store: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Medium: Missing Network Segmentation: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Medium: Missing Two-Factor Authentication (2FA): 2 Initial Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

Medium: Missing Vault (Secret Storage): 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Medium: Missing Web Application Firewall (WAF): 5 Initial Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to apply standard attack pattern tests at great speed without any filtering.

Medium: Unencrypted Technical Assets: 2 Initial Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Medium: **Unnecessary Data Transfer**: 4 Initial Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

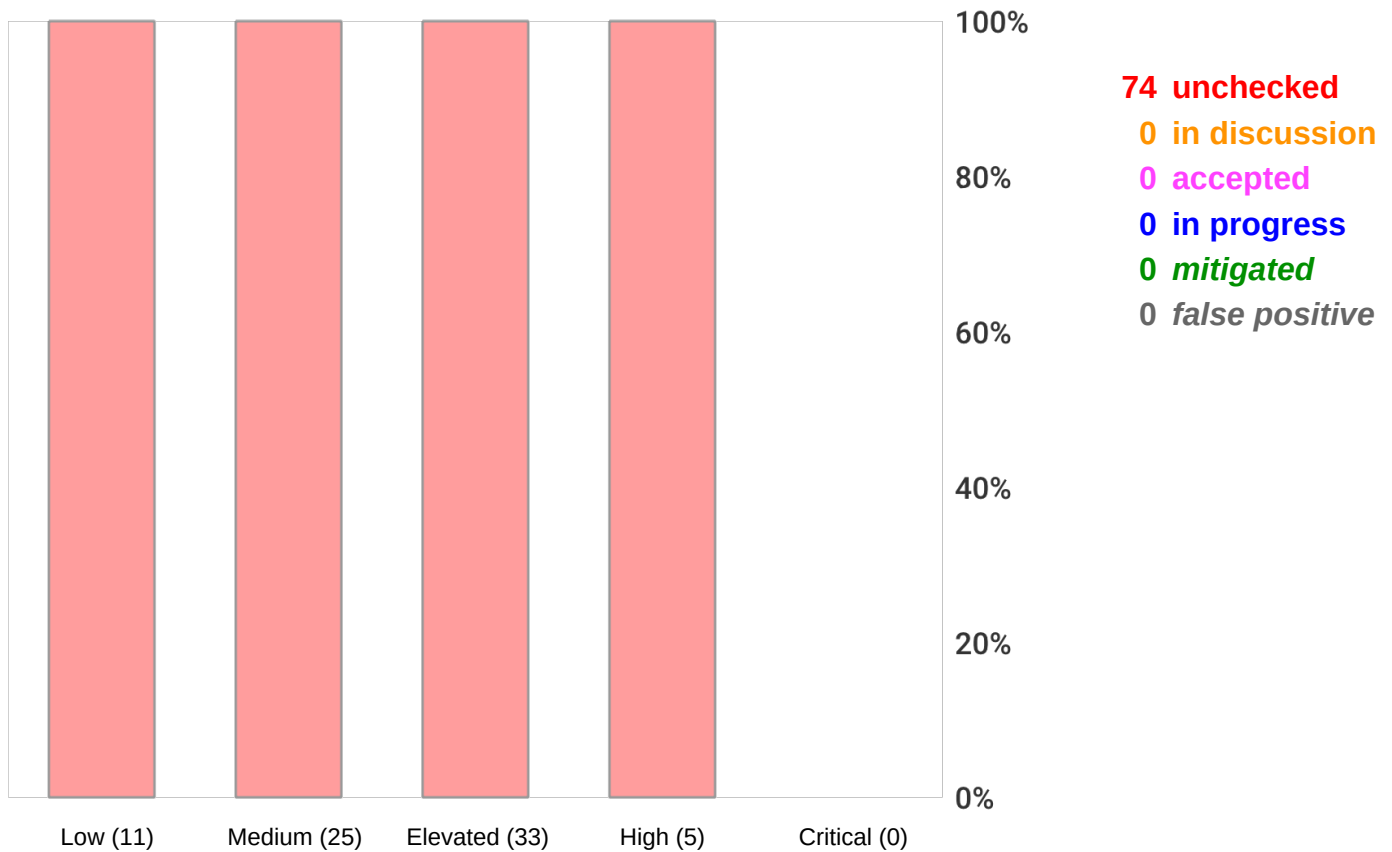
If this risk is unmitigated, attackers might be able to target unnecessarily transferred data.

Low: **DoS-risky Access Across Trust-Boundary**: 10 Initial Risks - Exploitation likelihood is *Unlikely* with *Low* impact.

If this risk remains unmitigated, attackers might be able to disturb the availability of important parts of the system.

Risk Mitigation

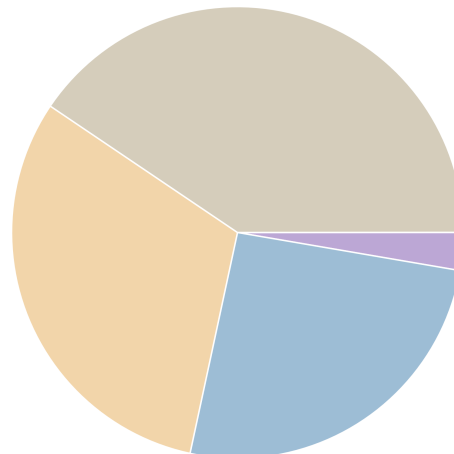
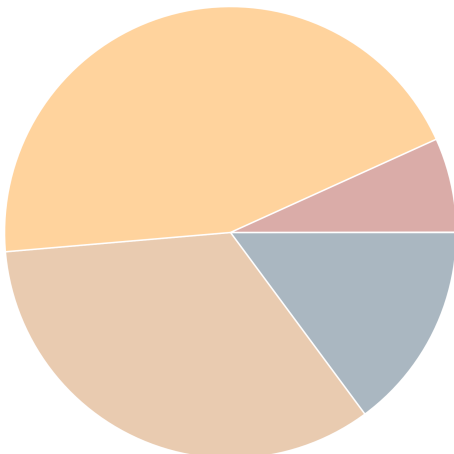
The following chart gives a high-level overview of the risk tracking status (including mitigated risks):



After removal of risks with status *mitigated* and *false positive* the following 74 remain unmitigated:

0 unmitigated critical risk
5 unmitigated high risk
33 unmitigated elevated risk
25 unmitigated medium risk
11 unmitigated low risk

2 business side related
19 architecture related
23 development related
30 operations related



Impact Analysis of 74 Remaining Risks in 20 Categories

The most prevalent impacts of the **74 remaining risks** (distributed over **20 risk categories**) are (taking the severity ratings into account and using the highest for each category):

Risk finding paragraphs are clickable and link to the corresponding chapter.

High: **SQL/NoSQL-Injection**: 5 Remaining Risks - Exploitation likelihood is *Very Likely with High impact*.

If this risk is unmitigated, attackers might be able to modify SQL/NoSQL queries to steal and modify data and eventually further escalate towards a deeper system penetration via code executions.

Elevated: **Cross-Site Request Forgery (CSRF)**: 4 Remaining Risks - Exploitation likelihood is *Very Likely with Medium impact*.

If this risk remains unmitigated, attackers might be able to trick logged-in victim users into unwanted actions within the web application by visiting an attacker controlled web site.

Elevated: **Cross-Site Scripting (XSS)**: 5 Remaining Risks - Exploitation likelihood is *Likely with High impact*.

If this risk remains unmitigated, attackers might be able to access individual victim sessions and steal or modify user data.

Elevated: **Missing Cloud Hardening**: 1 Remaining Risk - Exploitation likelihood is *Unlikely with Very High impact*.

If this risk is unmitigated, attackers might access cloud components in an unintended way.

Elevated: **Missing Hardening**: 3 Remaining Risks - Exploitation likelihood is *Likely with Medium impact*.

If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Elevated: **Missing Identity Provider Isolation**: 2 Remaining Risks - Exploitation likelihood is *Unlikely with Very High impact*.

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards highly sensitive identity provider assets and their identity datastores, as they are not separated by network segmentation.

Elevated: **Server-Side Request Forgery (SSRF)**: 9 Remaining Risks - Exploitation likelihood is *Likely with Medium impact*.

If this risk is unmitigated, attackers might be able to access sensitive services or files of network-reachable components by modifying outgoing calls of affected components.

Elevated: **Unguarded Access From Internet**: 4 Remaining Risks - Exploitation likelihood is *Very Likely with Medium impact*.

If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Elevated: Unguarded Direct Datastore Access: 5 Remaining Risks - Exploitation likelihood is *Likely with Medium impact*.

If this risk is unmitigated, attackers might be able to directly attack sensitive datastores without any protecting components in-between.

Medium: Container Base Image Backdooring: 6 Remaining Risks - Exploitation likelihood is *Unlikely with High impact*.

If this risk is unmitigated, attackers might be able to deeply persist in the target system by executing code in deployed containers.

Medium: Missing Build Infrastructure: 1 Remaining Risk - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Medium: Missing Identity Propagation: 3 Remaining Risks - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to access or modify foreign data after a successful compromise of a component within the system due to missing resource-based authorization checks.

Medium: Missing Identity Store: 1 Remaining Risk - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Medium: Missing Network Segmentation: 1 Remaining Risk - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Medium: Missing Two-Factor Authentication (2FA): 2 Remaining Risks - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

Medium: Missing Vault (Secret Storage): 1 Remaining Risk - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Medium: Missing Web Application Firewall (WAF): 5 Remaining Risks - Exploitation likelihood is *Unlikely with Medium impact*.

If this risk is unmitigated, attackers might be able to apply standard attack pattern tests at great speed without any filtering.

Medium: **Unencrypted Technical Assets**: 2 Remaining Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Medium: **Unnecessary Data Transfer**: 4 Remaining Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

If this risk is unmitigated, attackers might be able to target unnecessarily transferred data.

Low: **DoS-risky Access Across Trust-Boundary**: 10 Remaining Risks - Exploitation likelihood is *Unlikely* with *Low* impact.

If this risk remains unmitigated, attackers might be able to disturb the availability of important parts of the system.

Application Overview

Business Criticality

The overall business criticality of "DigiLocker Threat Model" was rated as:

(archive | operational | **IMPORTANT** | critical | mission-critical)

Business Overview

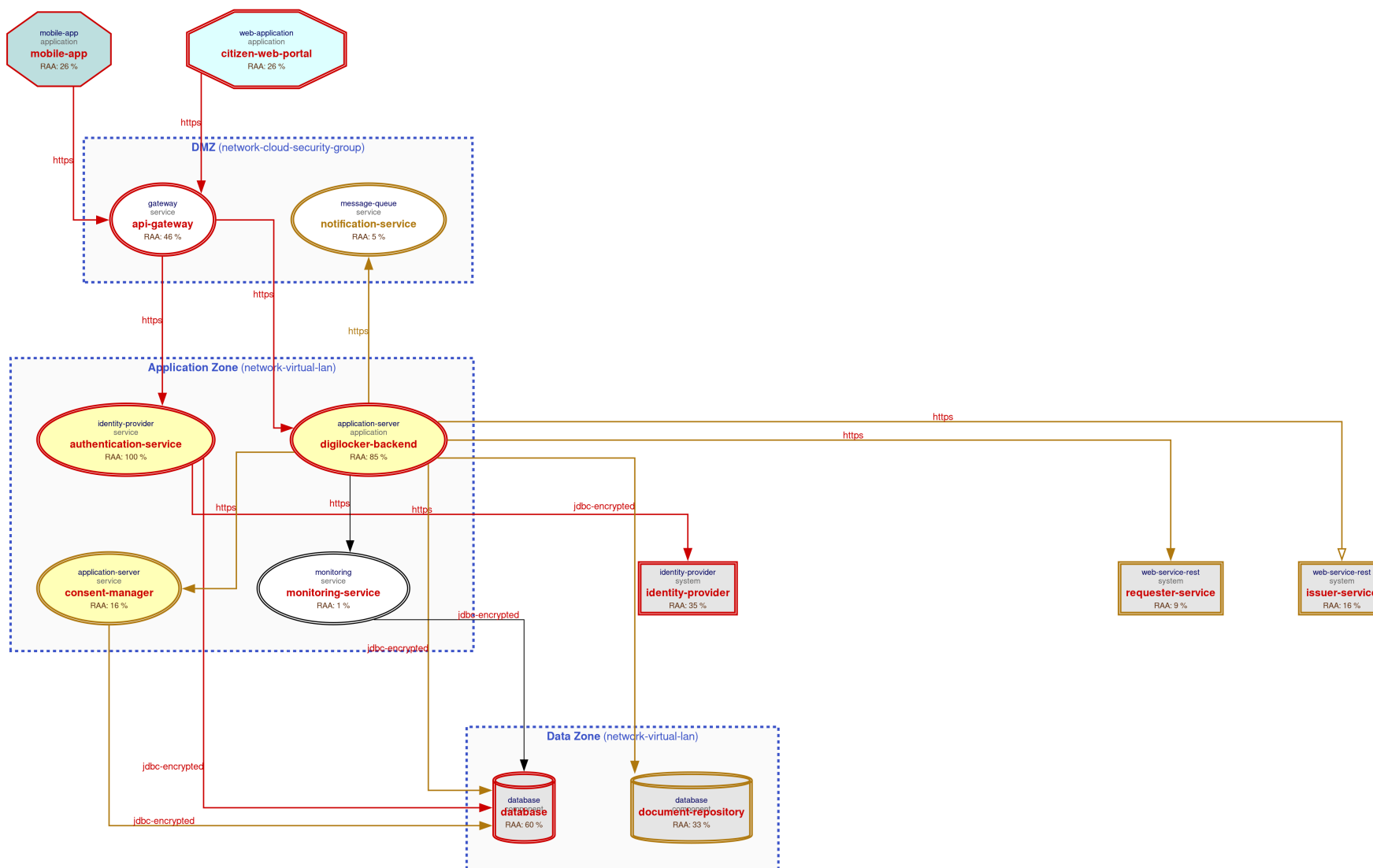
DigiLocker is a Government of India digital document wallet that enables citizens to securely store, access and share official digital documents.

Technical Overview

Data-Flow Diagram

The following diagram was generated by Threagile based on the model input and gives a high-level overview of the data-flow between technical assets. The RAA value is the calculated *Relative Attacker Attractiveness* in percent. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.

Data-Flow Diagram - DigiLocker Threat Model



Security Requirements

This chapter lists the custom security requirements which have been defined for the modeled target.

This list is not complete and regulatory or law relevant security requirements have to be taken into account as well. Also custom individual security requirements might exist for the project.

Abuse Cases

This chapter lists the custom abuse cases which have been defined for the modeled target.

This list is not complete and regulatory or law relevant abuse cases have to be taken into account as well. Also custom individual abuse cases might exist for the project.

Tag Listing

This chapter lists what tags are used by which elements.

STRIDE Classification of Identified Risks

This chapter clusters and classifies the risks by STRIDE categories: In total **74 potential risks** have been identified during the threat modeling process of which **5 in the Spoofing** category, **26 in the Tampering** category, **0 in the Repudiation** category, **12 in the Information Disclosure** category, **10 in the Denial of Service** category, and **21 in the Elevation of Privilege** category.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Spoofing

Elevated: **Cross-Site Request Forgery (CSRF)**: 4 / 4 Risks - Exploitation likelihood is *Very Likely with Medium impact*.

When a web application is accessed via web protocols Cross-Site Request Forgery (CSRF) risks might arise.

Medium: **Missing Identity Store**: 1 / 1 Risk - Exploitation likelihood is *Unlikely with Medium impact*.

The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Tampering

High: **SQL/NoSQL-Injection**: 5 / 5 Risks - Exploitation likelihood is *Very Likely with High impact*.

When a database is accessed via database access protocols SQL/NoSQL-Injection risks might arise. The risk rating depends on the sensitivity technical asset itself and of the data assets processed or stored.

Elevated: **Cross-Site Scripting (XSS)**: 5 / 5 Risks - Exploitation likelihood is *Likely with High impact*.

For each web application Cross-Site Scripting (XSS) risks might arise. In terms of the overall risk level take other applications running on the same domain into account as well.

Elevated: **Missing Cloud Hardening**: 1 / 1 Risk - Exploitation likelihood is *Unlikely with Very High impact*.

Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Elevated: **Missing Hardening**: 3 / 3 Risks - Exploitation likelihood is *Likely with Medium impact*.

Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.

Medium: **Container Base Image Backdooring**: 6 / 6 Risks - Exploitation likelihood is *Unlikely with High impact*.

When a technical asset is built using container technologies, Base Image Backdooring risks might arise where base images and other layers used contain vulnerable components or backdoors.

Medium: Missing Build Infrastructure: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Medium: Missing Web Application Firewall (WAF): 5 / 5 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

To have a first line of filtering defense, security architectures with web-services or web-applications should include a WAF in front of them. Even though a WAF is not a replacement for security (all components must be secure even without a WAF) it adds another layer of defense to the overall system by delaying some attacks and having easier attack alerting through it.

Repudiation

n/a

Information Disclosure

Elevated: Server-Side Request Forgery (SSRF): 9 / 9 Risks - Exploitation likelihood is *Likely* with *Medium* impact.

When a server system (i.e. not a client) is accessing other server systems via typical web protocols Server-Side Request Forgery (SSRF) or Local-File-Inclusion (LFI) or Remote-File-Inclusion (RFI) risks might arise.

Medium: Missing Vault (Secret Storage): 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Medium: Unencrypted Technical Assets: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.

Denial of Service

Low: **DoS-risky Access Across Trust-Boundary**: 10 / 10 Risks - Exploitation likelihood is *Unlikely* with *Low* impact.

Assets accessed across trust boundaries with critical or mission-critical availability rating are more prone to Denial-of-Service (DoS) risks.

Elevation of Privilege

Elevated: **Missing Identity Provider Isolation**: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *Very High* impact.

Highly sensitive identity provider assets and their identity datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).

Elevated: **Unguarded Access From Internet**: 4 / 4 Risks - Exploitation likelihood is *Very Likely* with *Medium* impact.

Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Elevated: **Unguarded Direct Datastore Access**: 5 / 5 Risks - Exploitation likelihood is *Likely* with *Medium* impact.

Datastores accessed across trust boundaries must be guarded by some protecting service or application.

Medium: **Missing Identity Propagation**: 3 / 3 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Technical assets (especially multi-tenant systems), which usually process data for endusers should authorize every request based on the identity of the enduser when the data flow is authenticated (i.e. non-public). For DevOps usages at least a technical-user authorization is required.

Medium: **Missing Network Segmentation**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webserver or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Medium: **Missing Two-Factor Authentication (2FA)**: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.

Medium: **Unnecessary Data Transfer**: 4 / 4 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

When a technical asset sends or receives data assets, which it neither processes or stores this is an indicator for unnecessarily transferred data (or for an incomplete model). When the unnecessarily transferred data assets are sensitive, this poses an unnecessary risk of an increased attack surface.

Assignment by Function

This chapter clusters and assigns the risks by functions which are most likely able to check and mitigate them: In total **74 potential risks** have been identified during the threat modeling process of which **2 should be checked by Business Side**, **19 should be checked by Architecture**, **23 should be checked by Development**, and **30 should be checked by Operations**.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Business Side

Medium: **Missing Two-Factor Authentication (2FA)**: 2 / 2 Risks - Exploitation likelihood is *Unlikely with Medium impact*.

Apply an authentication method to the technical asset protecting highly sensitive data via two-factor authentication for human users.

Architecture

Elevated: **Unguarded Access From Internet**: 4 / 4 Risks - Exploitation likelihood is *Very Likely with Medium impact*.

Encapsulate the asset behind a guarding service, application, or reverse-proxy. For admin maintenance a bastion-host should be used as a jump-server. For file transfer a store-and-forward-host should be used as an indirect file exchange platform.

Elevated: **Unguarded Direct Datastore Access**: 5 / 5 Risks - Exploitation likelihood is *Likely with Medium impact*.

Encapsulate the datastore access behind a guarding service or application.

Medium: **Missing Build Infrastructure**: 1 / 1 Risk - Exploitation likelihood is *Unlikely with Medium impact*.

Include the build infrastructure in the model.

Medium: **Missing Identity Propagation**: 3 / 3 Risks - Exploitation likelihood is *Unlikely with Medium impact*.

When processing requests for endusers if possible authorize in the backend against the propagated identity of the enduser. This can be achieved in passing JWTs or similar tokens and checking them in the backend services. For DevOps usages apply at least a technical-user authorization.

Medium: **Missing Identity Store**: 1 / 1 Risk - Exploitation likelihood is *Unlikely with Medium impact*.

Include an identity store in the model if the application has a login.

Medium: **Missing Vault (Secret Storage)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely with Medium impact*.

Consider using a Vault (Secret Storage) to securely store and access config secrets (like credentials, private keys, client certificates, etc.).

Medium: **Unnecessary Data Transfer**: 4 / 4 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Try to avoid sending or receiving sensitive data assets which are not required (i.e. neither processed or stored) by the involved technical asset.

Development

High: **SQL/NoSQL-Injection**: 5 / 5 Risks - Exploitation likelihood is *Very Likely* with *High* impact.

Try to use parameter binding to be safe from injection vulnerabilities. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

Elevated: **Cross-Site Request Forgery (CSRF)**: 4 / 4 Risks - Exploitation likelihood is *Very Likely* with *Medium* impact.

Try to use anti-CSRF tokens or the double-submit patterns (at least for logged-in requests). When your authentication scheme depends on cookies (like session or token cookies), consider marking them with the same-site flag. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

Elevated: **Cross-Site Scripting (XSS)**: 5 / 5 Risks - Exploitation likelihood is *Likely* with *High* impact.

Try to encode all values sent back to the browser and also handle DOM-manipulations in a safe way to avoid DOM-based XSS. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

Elevated: **Server-Side Request Forgery (SSRF)**: 9 / 9 Risks - Exploitation likelihood is *Likely* with *Medium* impact.

Try to avoid constructing the outgoing target URL with caller controllable values. Alternatively use a mapping (whitelist) when accessing outgoing URLs instead of creating them including caller controllable values. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

Operations

Elevated: **Missing Cloud Hardening**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Very High* impact.

Apply hardening of all cloud components and services, taking special care to follow the individual risk descriptions (which depend on the cloud provider tags in the model).

Elevated: **Missing Hardening**: 3 / 3 Risks - Exploitation likelihood is *Likely* with *Medium* impact.

Try to apply all hardening best practices (like CIS benchmarks, OWASP recommendations, vendor recommendations, DevSec Hardening Framework, DBSAT for Oracle databases, and others).

Elevated: Missing Identity Provider Isolation: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *Very High* impact.

Apply a network segmentation trust-boundary around the highly sensitive identity provider assets and their identity datastores.

Medium: Container Base Image Backdooring: 6 / 6 Risks - Exploitation likelihood is *Unlikely* with *High* impact.

Apply hardening of all container infrastructures (see for example the *CIS-Benchmarks for Docker and Kubernetes* and the *Docker Bench for Security*). Use only trusted base images of the original vendors, verify digital signatures and apply image creation best practices. Also consider using Google's *Distroless* base images or otherwise very small base images. Regularly execute container image scans with tools checking the layers for vulnerable components.

Medium: Missing Network Segmentation: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

Apply a network segmentation trust-boundary around the highly sensitive assets and/or datastores.

Medium: Missing Web Application Firewall (WAF): 5 / 5 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Consider placing a Web Application Firewall (WAF) in front of the web-services and/or web-applications. For cloud environments many cloud providers offer pre-configured WAFs. Even reverse proxies can be enhanced by a WAF component via ModSecurity plugins.

Medium: Unencrypted Technical Assets: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

Apply encryption to the technical asset.

Low: DoS-risky Access Across Trust-Boundary: 10 / 10 Risks - Exploitation likelihood is *Unlikely* with *Low* impact.

Apply anti-DoS techniques like throttling and/or per-client load blocking with quotas. Also for maintenance access routes consider applying a VPN instead of public reachable interfaces. Generally applying redundancy on the targeted technical asset reduces the risk of DoS.

RAA Analysis

For each technical asset the "**Relative Attacker Attractiveness**" (RAA) value was calculated in percent. The higher the RAA, the more interesting it is for an attacker to compromise the asset. The calculation algorithm takes the sensitivity ratings and quantities of stored and processed data into account as well as the communication links of the technical asset. Neighbouring assets to high-value RAA targets might receive an increase in their RAA value when they have a communication link towards that target ("Pivoting-Factor").

The following lists all technical assets sorted by their RAA value from highest (most attacker attractive) to lowest. This list can be used to prioritize on efforts relevant for the most attacker-attractive technical assets:

Technical asset paragraphs are clickable and link to the corresponding chapter.

authentication-service: RAA 100%

Single Sign-On Authentication Service

digilocker-backend: RAA 85%

DigiLocker Core Backend

database: RAA 60%

DigiLocker Relational Database

api-gateway: RAA 46%

API Gateway

identity-provider: RAA 35%

Aadhaar Identity Provider

document-repository: RAA 33%

Secure Document Repository

citizen-web-portal: RAA 26%

DigiLocker Citizen Web Portal

mobile-app: RAA 26%

DigiLocker Mobile Application

consent-manager: RAA 16%

Consent Management Service

issuer-service: RAA 16%

Government Issuer Service

requester-service: RAA 9%

Requester Verification Service

notification-service: RAA 5%

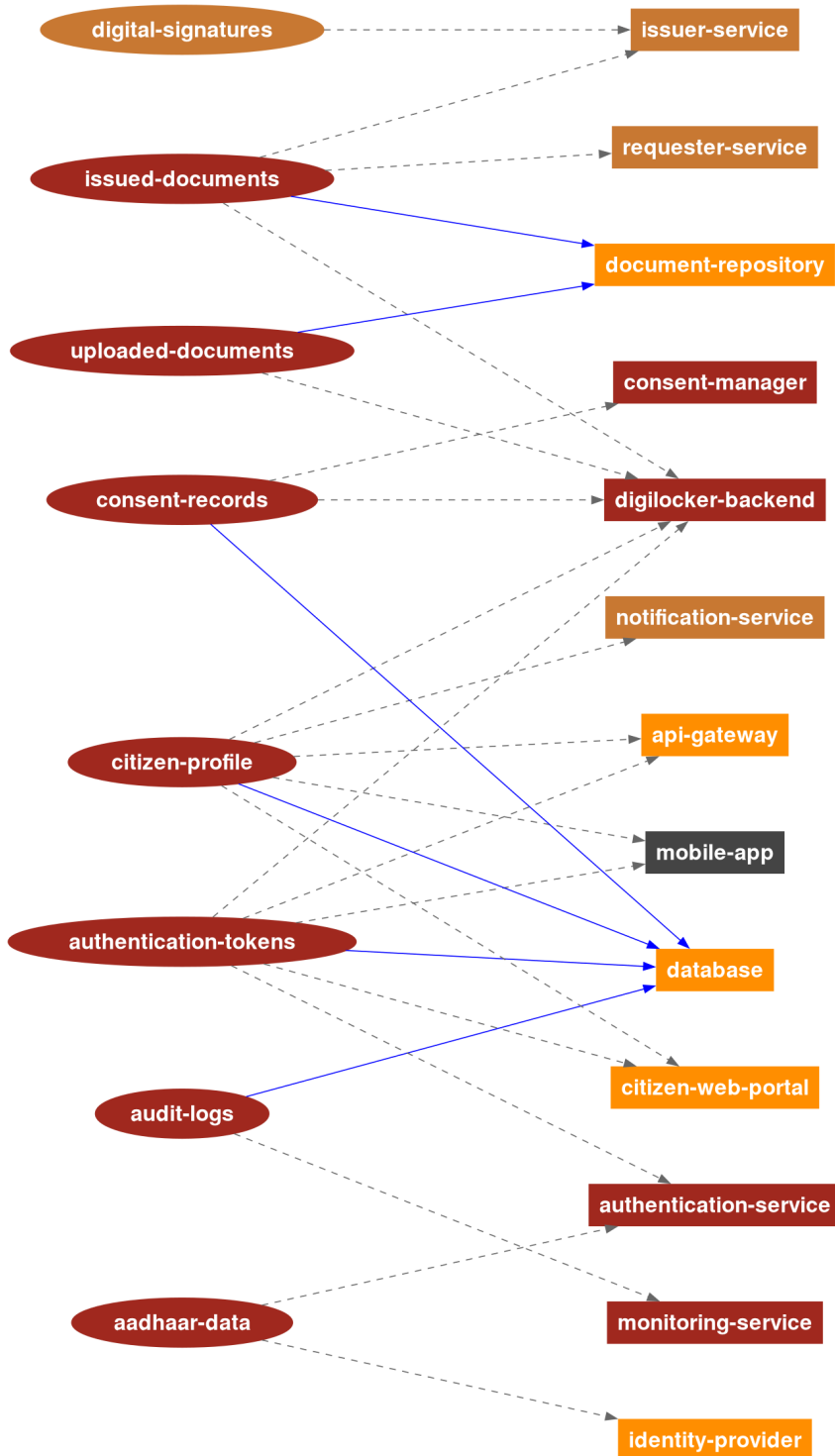
Email and SMS Notification Service

monitoring-service: RAA 1%

Monitoring and Audit Service

Data Mapping

The following diagram was generated by Threagile based on the model input and gives a high-level distribution of data assets across technical assets. The color matches the identified data breach probability and risk level (see the "Data Breach Probabilities" chapter for more details). A solid line stands for *data is stored by the asset* and a dashed one means *data is processed by the asset*. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.



Out-of-Scope Assets: 0 Assets

This chapter lists all technical assets that have been defined as out-of-scope. Each one should be checked in the model whether it should better be included in the overall risk analysis:

Technical asset paragraphs are clickable and link to the corresponding chapter.

No technical assets have been defined as out-of-scope.

Potential Model Failures: 7 / 7 Risks

This chapter lists potential model failures where not all relevant assets have been modeled or the model might itself contain inconsistencies. Each potential model failure should be checked in the model against the architecture design:

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium: Missing Build Infrastructure: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Medium: Missing Identity Store: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Medium: Missing Vault (Secret Storage): 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Medium: Unnecessary Data Transfer: 4 / 4 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

When a technical asset sends or receives data assets, which it neither processes or stores this is an indicator for unnecessarily transferred data (or for an incomplete model). When the unnecessarily transferred data assets are sensitive, this poses an unnecessary risk of an increased attack surface.

Questions: 0 / 0 Questions

This chapter lists custom questions that arose during the threat modeling process.

No custom questions arose during the threat modeling process.

Identified Risks by Vulnerability Category

In total **74 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 5 as high, 33 as elevated, 25 as medium, and 11 as low.**

These risks are distributed across **20 vulnerability categories**. The following sub-chapters of this section describe each identified risk category.

SQL/NoSQL-Injection: 5 / 5 Risks

Description (Tampering): [CWE 89](#)

When a database is accessed via database access protocols SQL/NoSQL-Injection risks might arise. The risk rating depends on the sensitivity technical asset itself and of the data assets processed or stored.

Impact

If this risk is unmitigated, attackers might be able to modify SQL/NoSQL queries to steal and modify data and eventually further escalate towards a deeper system penetration via code executions.

Detection Logic

Database accessed via typical database access protocols by in-scope clients.

Risk Rating

The risk rating depends on the sensitivity of the data stored inside the database.

False Positives

Database accesses by queries not consisting of parts controllable by the caller can be considered as false positives after individual review.

Mitigation (Development): SQL/NoSQL-Injection Prevention

Try to use parameter binding to be safe from injection vulnerabilities. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

ASVS Chapter: [V5 - Validation, Sanitization and Encoding Verification Requirements](#)

Cheat Sheet: [SQL_Injection_Prevention_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **SQL/NoSQL-Injection** was found **5 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

SQL/NoSQL-Injection risk at **authentication-service** against database **database** via **Auth Service to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database](#)

Unchecked

SQL/NoSQL-Injection risk at **consent-manager** against database **database** via **Consent Manager to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database](#)

Unchecked

SQL/NoSQL-Injection risk at **digilocker-backend** against database **database** via **Backend to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database](#)

Unchecked

SQL/NoSQL-Injection risk at **digilocker-backend** against database **document-repository** via **Backend to Document Repository**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@digilocker-backend@document-repository@digilocker-backend>backend-to-document-repository](#)

Unchecked

SQL/NoSQL-Injection risk at **monitoring-service** against database **database** via **Monitoring Service to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database](#)

Unchecked

Cross-Site Request Forgery (CSRF): 4 / 4 Risks

Description (Spoofing): [CWE 352](#)

When a web application is accessed via web protocols Cross-Site Request Forgery (CSRF) risks might arise.

Impact

If this risk remains unmitigated, attackers might be able to trick logged-in victim users into unwanted actions within the web application by visiting an attacker controlled web site.

Detection Logic

In-scope web applications accessed via typical web access protocols.

Risk Rating

The risk rating depends on the integrity rating of the data sent across the communication link.

False Positives

Web applications passing the authentication state via custom headers instead of cookies can eventually be false positives. Also when the web application is not accessed via a browser-like component (i.e not by a human user initiating the request that gets passed through all components until it reaches the web application) this can be considered a false positive.

Mitigation (Development): CSRF Prevention

Try to use anti-CSRF tokens or the double-submit patterns (at least for logged-in requests). When your authentication scheme depends on cookies (like session or token cookies), consider marking them with the same-site flag. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

ASVS Chapter: [V4 - Access Control Verification Requirements](#)

Cheat Sheet: [Cross-Site_Request_Forgery_Prevention_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Cross-Site Request Forgery (CSRF)** was found **4 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Cross-Site Request Forgery (CSRF) risk at authentication-service via Gateway to Authentication Service from api-gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

[cross-site-request-forgery@authentication-service@api-gateway>gateway-to-authentication-service](#)

Unchecked

Cross-Site Request Forgery (CSRF) risk at consent-manager via Backend to Consent Manager from digilocker-backend: Exploitation likelihood is *Very Likely* with *Medium* impact.

[cross-site-request-forgery@consent-manager@digilocker-backend>backend-to-consent-manager](#)

Unchecked

Cross-Site Request Forgery (CSRF) risk at digilocker-backend via Gateway to DigiLocker Backend from api-gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

[cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend](#)

Unchecked

Cross-Site Request Forgery (CSRF) risk at identity-provider via Auth Service to Aadhaar Identity Provider from authentication-service: Exploitation likelihood is *Very Likely* with *Medium* impact.

[cross-site-request-forgery@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider](#)

Unchecked

Cross-Site Scripting (XSS): 5 / 5 Risks

Description (Tampering): [CWE 79](#)

For each web application Cross-Site Scripting (XSS) risks might arise. In terms of the overall risk level take other applications running on the same domain into account as well.

Impact

If this risk remains unmitigated, attackers might be able to access individual victim sessions and steal or modify user data.

Detection Logic

In-scope web applications.

Risk Rating

The risk rating depends on the sensitivity of the data processed or stored in the web application.

False Positives

When the technical asset is not accessed via a browser-like component (i.e not by a human user initiating the request that gets passed through all components until it reaches the web application) this can be considered a false positive.

Mitigation (Development): XSS Prevention

Try to encode all values sent back to the browser and also handle DOM-manipulations in a safe way to avoid DOM-based XSS. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

ASVS Chapter: [V5 - Validation, Sanitization and Encoding Verification Requirements](#)

Cheat Sheet: [Cross Site Scripting Prevention Cheat Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Cross-Site Scripting (XSS)** was found **5 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Cross-Site Scripting (XSS) risk at **authentication-service**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@authentication-service](#)

Unchecked

Cross-Site Scripting (XSS) risk at **citizen-web-portal**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@citizen-web-portal](#)

Unchecked

Cross-Site Scripting (XSS) risk at **consent-manager**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@consent-manager](#)

Unchecked

Cross-Site Scripting (XSS) risk at **digilocker-backend**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@digilocker-backend](#)

Unchecked

Cross-Site Scripting (XSS) risk at **identity-provider**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@identity-provider](#)

Unchecked

Missing Cloud Hardening: 1 / 1 Risk

Description (Tampering): [CWE 1008](#)

Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Impact

If this risk is unmitigated, attackers might access cloud components in an unintended way.

Detection Logic

In-scope cloud components (either residing in cloud trust boundaries or more specifically tagged with cloud provider types).

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Cloud components not running parts of the target architecture can be considered as false positives after individual review.

Mitigation (Operations): Cloud Hardening

Apply hardening of all cloud components and services, taking special care to follow the individual risk descriptions (which depend on the cloud provider tags in the model).

For **Amazon Web Services (AWS)**: Follow the *CIS Benchmark for Amazon Web Services* (see also the automated checks of cloud audit tools like "PacBot", "CloudSploit", "CloudMapper", "ScoutSuite", or "Prowler AWS CIS Benchmark Tool").

For EC2 and other servers running Amazon Linux, follow the *CIS Benchmark for Amazon Linux* and switch to IMDSv2.

For S3 buckets follow the *Security Best Practices for Amazon S3* at

<https://docs.aws.amazon.com/AmazonS3/latest/dev/security-best-practices.html> to avoid accidental leakage.

Also take a look at some of these tools: <https://github.com/toniblyx/my-arsenal-of-aws-security-tools>

For **Microsoft Azure**: Follow the *CIS Benchmark for Microsoft Azure* (see also the automated checks of cloud audit tools like "CloudSploit" or "ScoutSuite").

For **Google Cloud Platform**: Follow the *CIS Benchmark for Google Cloud Computing Platform* (see also the automated checks of cloud audit tools like "*CloudSploit*" or "*ScoutSuite*").

For **Oracle Cloud Platform**: Follow the hardening best practices (see also the automated checks of cloud audit tools like "*CloudSploit*").

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Cloud Hardening** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Cloud Hardening risk at **DMZ**: Exploitation likelihood is *Unlikely* with *Very High* impact.

[missing-cloud-hardening@dmz](#)

Unchecked

Missing Hardening: 3 / 3 Risks

Description (Tampering): [CWE 16](#)

Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.

Impact

If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Detection Logic

In-scope technical assets with RAA values of 55 % or higher. Generally for high-value targets like datastores, application servers, identity providers and ERP systems this limit is reduced to 40 %

Risk Rating

The risk rating depends on the sensitivity of the data processed or stored in the technical asset.

False Positives

Usually no false positives.

Mitigation (Operations): System Hardening

Try to apply all hardening best practices (like CIS benchmarks, OWASP recommendations, vendor recommendations, DevSec Hardening Framework, DBSAT for Oracle databases, and others).

ASVS Chapter: [V14 - Configuration Verification Requirements](#)

Cheat Sheet: [Attack Surface Analysis Cheat Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Hardening** was found **3 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Hardening risk at **authentication-service**: Exploitation likelihood is *Likely* with *Medium* impact.

[missing-hardening@authentication-service](#)

Unchecked

Missing Hardening risk at **database**: Exploitation likelihood is *Likely* with *Medium* impact.

[missing-hardening@database](#)

Unchecked

Missing Hardening risk at **digilocker-backend**: Exploitation likelihood is *Likely* with *Medium* impact.

[missing-hardening@digilocker-backend](#)

Unchecked

Missing Identity Provider Isolation: 2 / 2 Risks

Description (Elevation of Privilege): [CWE 1008](#)

Highly sensitive identity provider assets and their identity datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).

Impact

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards highly sensitive identity provider assets and their identity datastores, as they are not separated by network segmentation.

Detection Logic

In-scope identity provider assets and their identity datastores when surrounded by other (not identity-related) assets (without a network trust-boundary in-between). This risk is especially prevalent when other non-identity related assets are within the same execution environment (i.e. same database or same application server).

Risk Rating

Default is high impact. The impact is increased to very-high when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

False Positives

When all assets within the network segmentation trust-boundary are hardened and protected to the same extent as if all were identity providers with data of highest sensitivity.

Mitigation (Operations): Network Segmentation

Apply a network segmentation trust-boundary around the highly sensitive identity provider assets and their identity datastores.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Identity Provider Isolation** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Identity Provider Isolation to further encapsulate and protect identity-related asset **authentication-service** against unrelated lower protected assets **in the same network segment**, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Very High* impact.

[missing-identity-provider-isolation@authentication-service](#)

Unchecked

Missing Identity Provider Isolation to further encapsulate and protect identity-related asset **identity-provider** against unrelated lower protected assets **in the same network segment**, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Very High* impact.

[missing-identity-provider-isolation@identity-provider](#)

Unchecked

Server-Side Request Forgery (SSRF): 9 / 9 Risks

Description (Information Disclosure): [CWE 918](#)

When a server system (i.e. not a client) is accessing other server systems via typical web protocols Server-Side Request Forgery (SSRF) or Local-File-Inclusion (LFI) or Remote-File-Inclusion (RFI) risks might arise.

Impact

If this risk is unmitigated, attackers might be able to access sensitive services or files of network-reachable components by modifying outgoing calls of affected components.

Detection Logic

In-scope non-client systems accessing (using outgoing communication links) targets with either HTTP or HTTPS protocol.

Risk Rating

The risk rating (low or medium) depends on the sensitivity of the data assets receivable via web protocols from targets within the same network trust-boundary as well on the sensitivity of the data assets receivable via web protocols from the target asset itself. Also for cloud-based environments the exploitation impact is at least medium, as cloud backend services can be attacked via SSRF.

False Positives

Servers not sending outgoing web requests can be considered as false positives after review.

Mitigation (Development): SSRF Prevention

Try to avoid constructing the outgoing target URL with caller controllable values. Alternatively use a mapping (whitelist) when accessing outgoing URLs instead of creating them including caller controllable values. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

ASVS Chapter: [V12 - File and Resources Verification Requirements](#)

Cheat Sheet: [Server_Side_Request_Forgery_Prevention_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Server-Side Request Forgery (SSRF)** was found **9 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Server-Side Request Forgery (SSRF) risk at **api-gateway** server-side web-requesting the target **authentication-service** via **Gateway to Authentication Service**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@api-gateway@authentication-service@api-gateway>gateway-to-authentication-service`

Unchecked

Server-Side Request Forgery (SSRF) risk at **api-gateway** server-side web-requesting the target **digilocker-backend** via **Gateway to DigiLocker Backend**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@api-gateway@digilocker-backend@api-gateway>gateway-to-digilocker-backend`

Unchecked

Server-Side Request Forgery (SSRF) risk at **authentication-service** server-side web-requesting the target **identity-provider** via **Auth Service to Aadhaar Identity Provider**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider`

Unchecked

Server-Side Request Forgery (SSRF) risk at **citizen-web-portal** server-side web-requesting the target **api-gateway** via **Web Portal to API Gateway**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway`

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **consent-manager** via **Backend to Consent Manager**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager`

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **issuer-service** via **Backend to Issuer Service**: Exploitation likelihood is *Likely with Medium* impact.

`server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service`

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **monitoring-service** via **Backend to Monitoring Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **notification-service** via **Backend to Notification Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **requester-service** via **Backend to Requester Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Unchecked

Unguarded Access From Internet: 4 / 4 Risks

Description (Elevation of Privilege): [CWE 501](#)

Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Impact

If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Detection Logic

In-scope technical assets (excluding load-balancer) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) when accessed directly from the internet. All web-server, web-application, reverse-proxy, waf, and gateway assets are exempted from this risk when they do not consist of custom developed code and the data-flow only consists of HTTP or FTP protocols. Access from monitoring systems as well as VPN-protected connections are exempted.

Risk Rating

The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

False Positives

When other means of filtering client requests are applied equivalent of reverse-proxy, waf, or gateway components.

Mitigation (Architecture): Encapsulation of Technical Asset

Encapsulate the asset behind a guarding service, application, or reverse-proxy. For admin maintenance a bastion-host should be used as a jump-server. For file transfer a store-and-forward-host should be used as an indirect file exchange platform.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unguarded Access From Internet** was found **4 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unguarded Access from Internet of api-gateway by citizen-web-portal via Web Portal to API Gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

[unguarded-access-from-internet@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway](#)

Unchecked

Unguarded Access from Internet of api-gateway by mobile-app via Mobile App to API Gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

[unguarded-access-from-internet@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway](#)

Unchecked

Unguarded Access from Internet of authentication-service by api-gateway via Gateway to Authentication Service: Exploitation likelihood is *Very Likely* with *Medium* impact.

[unguarded-access-from-internet@authentication-service@api-gateway@api-gateway>gateway-to-authentication-service](#)

Unchecked

Unguarded Access from Internet of digilocker-backend by api-gateway via Gateway to DigiLocker Backend: Exploitation likelihood is *Very Likely* with *Medium* impact.

[unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend](#)

Unchecked

Unguarded Direct Datastore Access: 5 / 5 Risks

Description (Elevation of Privilege): [CWE 501](#)

Datastores accessed across trust boundaries must be guarded by some protecting service or application.

Impact

If this risk is unmitigated, attackers might be able to directly attack sensitive datastores without any protecting components in-between.

Detection Logic

In-scope technical assets of type datastore (except identity-store-ldap when accessed from identity-provider and file-server when accessed via file transfer protocols) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) which have incoming data-flows from assets outside across a network trust-boundary. DevOps config and deployment access is excluded from this risk.

Risk Rating

The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

False Positives

When the caller is considered fully trusted as if it was part of the datastore itself.

Mitigation (Architecture): Encapsulation of Datastore

Encapsulate the datastore access behind a guarding service or application.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unguarded Direct Datastore Access** was found **5 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unguarded Direct Datastore Access of database by authentication-service via Auth Service to Database: Exploitation likelihood is *Likely* with *Medium* impact.

`unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database`

Unchecked

Unguarded Direct Datastore Access of database by consent-manager via Consent Manager to Database: Exploitation likelihood is *Likely* with *Medium* impact.

`unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database`

Unchecked

Unguarded Direct Datastore Access of database by digilocker-backend via Backend to Database: Exploitation likelihood is *Likely* with *Medium* impact.

`unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database`

Unchecked

Unguarded Direct Datastore Access of database by monitoring-service via Monitoring Service to Database: Exploitation likelihood is *Likely* with *Medium* impact.

`unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database`

Unchecked

Unguarded Direct Datastore Access of document-repository by digilocker-backend via Backend to Document Repository: Exploitation likelihood is *Likely* with *Medium* impact.

`unguarded-direct-datastore-access@digilocker-backend>backend-to-document-repository@digilocker-backend@document-repository`

Unchecked

Container Base Image Backdooring: 6 / 6 Risks

Description (Tampering): [CWE 912](#)

When a technical asset is built using container technologies, Base Image Backdooring risks might arise where base images and other layers used contain vulnerable components or backdoors.

See for example:

<https://techcrunch.com/2018/06/15/tainted-crypto-mining-containers-pulled-from-docker-hub/>

Impact

If this risk is unmitigated, attackers might be able to deeply persist in the target system by executing code in deployed containers.

Detection Logic

In-scope technical assets running as containers.

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets.

False Positives

Fully trusted (i.e. reviewed and cryptographically signed or similar) base images of containers can be considered as false positives after individual review.

Mitigation (Operations): Container Infrastructure Hardening

Apply hardening of all container infrastructures (see for example the *CIS-Benchmarks for Docker and Kubernetes* and the *Docker Bench for Security*). Use only trusted base images of the original vendors, verify digital signatures and apply image creation best practices. Also consider using Google's *Distroless* base images or otherwise very small base images. Regularly execute container image scans with tools checking the layers for vulnerable components.

ASVS Chapter: [V10 - Malicious Code Verification Requirements](#)

Cheat Sheet: [Docker_Security_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS/CSVS applied?

Risk Findings

The risk **Container Base Image Backdooring** was found **6 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Container Base Image Backdooring risk at **api-gateway**: Exploitation likelihood is *Unlikely with High* impact.

[container-baseimage-backdooring@api-gateway](#)

Unchecked

Container Base Image Backdooring risk at **authentication-service**: Exploitation likelihood is *Unlikely with High* impact.

[container-baseimage-backdooring@authentication-service](#)

Unchecked

Container Base Image Backdooring risk at **consent-manager**: Exploitation likelihood is *Unlikely with High* impact.

[container-baseimage-backdooring@consent-manager](#)

Unchecked

Container Base Image Backdooring risk at **digilocker-backend**: Exploitation likelihood is *Unlikely with High* impact.

[container-baseimage-backdooring@digilocker-backend](#)

Unchecked

Container Base Image Backdooring risk at **monitoring-service**: Exploitation likelihood is *Unlikely with High* impact.

[container-baseimage-backdooring@monitoring-service](#)

Unchecked

Container Base Image Backdooring risk at **notification-service**: Exploitation likelihood is *Unlikely with Medium* impact.

[container-baseimage-backdooring@notification-service](#)

Unchecked

Missing Build Infrastructure: 1 / 1 Risk

Description (Tampering): [CWE 1127](#)

The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Impact

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Detection Logic

Models with in-scope custom-developed parts missing in-scope development (code creation) and build infrastructure components (devops-client, sourcecode-repo, build-pipeline, etc.).

Risk Rating

The risk rating depends on the highest sensitivity of the in-scope assets running custom-developed parts.

False Positives

Models not having any custom-developed parts can be considered as false positives after individual review.

Mitigation (Architecture): Build Pipeline Hardening

Include the build infrastructure in the model.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Build Infrastructure** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Build Infrastructure in the threat model (referencing asset **authentication-service** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-build-infrastructure@authentication-service](#)

Unchecked

Missing Identity Propagation: 3 / 3 Risks

Description (Elevation of Privilege): [CWE 284](#)

Technical assets (especially multi-tenant systems), which usually process data for endusers should authorize every request based on the identity of the enduser when the data flow is authenticated (i.e. non-public). For DevOps usages at least a technical-user authorization is required.

Impact

If this risk is unmitigated, attackers might be able to access or modify foreign data after a successful compromise of a component within the system due to missing resource-based authorization checks.

Detection Logic

In-scope service-like technical assets which usually process data based on enduser requests, if authenticated (i.e. non-public), should authorize incoming requests based on the propagated enduser identity when their rating is sensitive. This is especially the case for all multi-tenant assets (there even less-sensitive rated ones). DevOps usages are exempted from this risk.

Risk Rating

The risk rating (medium or high) depends on the confidentiality, integrity, and availability rating of the technical asset.

False Positives

Technical assets which do not process requests regarding functionality or data linked to end-users (customers) can be considered as false positives after individual review.

Mitigation (Architecture): Identity Propagation and Resource-based Authorization

When processing requests for endusers if possible authorize in the backend against the propagated identity of the enduser. This can be achieved in passing JWTs or similar tokens and checking them in the backend services. For DevOps usages apply at least a technical-user authorization.

ASVS Chapter: [V4 - Access Control Verification Requirements](#)

Cheat Sheet: [Access_Control_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Identity Propagation** was found **3 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Enduser Identity Propagation over communication link **Backend to Consent Manager** from **digilocker-backend** to **consent-manager**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-propagation@digilocker-backend>backend-to-consent-manager@digilocker-backend@consent-manager](#)

Unchecked

Missing Enduser Identity Propagation over communication link **Backend to Issuer Service** from **digilocker-backend** to **issuer-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-propagation@digilocker-backend>backend-to-issuer-service@digilocker-backend@issuer-service](#)

Unchecked

Missing Enduser Identity Propagation over communication link **Backend to Requester Service** from **digilocker-backend** to **requester-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-propagation@digilocker-backend>backend-to-requester-service@digilocker-backend@requester-service](#)

Unchecked

Missing Identity Store: 1 / 1 Risk

Description (Spoofing): [CWE 287](#)

The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Impact

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Detection Logic

Models with authenticated data-flows authorized via enduser-identity missing an in-scope identity store.

Risk Rating

The risk rating depends on the sensitivity of the enduser-identity authorized technical assets and their data assets processed and stored.

False Positives

Models only offering data/services without any real authentication need can be considered as false positives after individual review.

Mitigation (Architecture): Identity Store

Include an identity store in the model if the application has a login.

ASVS Chapter: [V2 - Authentication Verification Requirements](#)

Cheat Sheet: [Authentication_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Identity Store** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Identity Store in the threat model (referencing asset **digilocker-backend** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-store@digilocker-backend](#)

Unchecked

Missing Network Segmentation: 1 / 1 Risk

Description (Elevation of Privilege): [CWE 1008](#)

Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webserver or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Impact

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Detection Logic

In-scope technical assets with high sensitivity and RAA values as well as datastores when surrounded by assets (without a network trust-boundary in-between) which are of type client-system, web-server, web-application, cms, web-service-rest, web-service-soap, build-pipeline, sourcecode-repository, monitoring, or similar and there is no direct connection between these (hence no requirement to be so close to each other).

Risk Rating

Default is low risk. The risk is increased to medium when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

False Positives

When all assets within the network segmentation trust-boundary are hardened and protected to the same extend as if all were containing/processing highly sensitive data.

Mitigation (Operations): Network Segmentation

Apply a network segmentation trust-boundary around the highly sensitive assets and/or datastores.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Network Segmentation** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Network Segmentation to further encapsulate and protect **authentication-service** against unrelated lower protected assets in the same network segment, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-network-segmentation@authentication-service](#)

Unchecked

Missing Two-Factor Authentication (2FA): 2 / 2 Risks

Description (Elevation of Privilege): [CWE 308](#)

Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.

Impact

If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

Detection Logic

In-scope technical assets (except load-balancer, reverse-proxy, waf, ids, and ips) should authenticate incoming requests via two-factor authentication (2FA) when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by a client used by a human user.

Risk Rating

medium

False Positives

Technical assets which do not process requests regarding functionality or data linked to end-users (customers) can be considered as false positives after individual review.

Mitigation (Business Side): Authentication with Second Factor (2FA)

Apply an authentication method to the technical asset protecting highly sensitive data via two-factor authentication for human users.

ASVS Chapter: [V2 - Authentication Verification Requirements](#)

Cheat Sheet: [Multifactor_Authentication_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Two-Factor Authentication (2FA)** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Two-Factor Authentication covering communication link **Mobile App to API Gateway** from **mobile-app** to **api-gateway**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-authentication-second-factor@mobile-app>mobile-app-to-api-gateway@mobile-app@api-gateway](#)

Unchecked

Missing Two-Factor Authentication covering communication link **Web Portal to API Gateway** from **citizen-web-portal** to **api-gateway**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-authentication-second-factor@citizen-web-portal>web-portal-to-api-gateway@citizen-web-portal@api-gateway](#)

Unchecked

Missing Vault (Secret Storage): 1 / 1 Risk

Description (Information Disclosure): [CWE 522](#)

In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Impact

If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Detection Logic

Models without a Vault (Secret Storage).

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Models where no technical assets have any kind of sensitive config data to protect can be considered as false positives after individual review.

Mitigation (Architecture): Vault (Secret Storage)

Consider using a Vault (Secret Storage) to securely store and access config secrets (like credentials, private keys, client certificates, etc.).

ASVS Chapter: [V6 - Stored Cryptography Verification Requirements](#)

Cheat Sheet: [Cryptographic_Storage_Cheat_Sheet](#)

Check

Is a Vault (Secret Storage) in place?

Risk Findings

The risk **Missing Vault (Secret Storage)** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Vault (Secret Storage) in the threat model (referencing asset **authentication-service** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-vault@authentication-service](#)

Unchecked

Missing Web Application Firewall (WAF): 5 / 5 Risks

Description (Tampering): [CWE 1008](#)

To have a first line of filtering defense, security architectures with web-services or web-applications should include a WAF in front of them. Even though a WAF is not a replacement for security (all components must be secure even without a WAF) it adds another layer of defense to the overall system by delaying some attacks and having easier attack alerting through it.

Impact

If this risk is unmitigated, attackers might be able to apply standard attack pattern tests at great speed without any filtering.

Detection Logic

In-scope web-services and/or web-applications accessed across a network trust boundary not having a Web Application Firewall (WAF) in front of them.

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Targets only accessible via WAFs or reverse proxies containing a WAF component (like ModSecurity) can be considered as false positives after individual review.

Mitigation (Operations): Web Application Firewall (WAF)

Consider placing a Web Application Firewall (WAF) in front of the web-services and/or web-applications. For cloud environments many cloud providers offer pre-configured WAFs. Even reverse proxies can be enhanced by a WAF component via ModSecurity plugins.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Virtual Patching Cheat Sheet](#)

Check

Is a Web Application Firewall (WAF) in place?

Risk Findings

The risk **Missing Web Application Firewall (WAF)** was found **5 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Web Application Firewall (WAF) risk at **authentication-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@authentication-service](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **digilocker-backend**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@digilocker-backend](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **identity-provider**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@identity-provider](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **issuer-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@issuer-service](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **requester-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@requester-service](#)

Unchecked

Unencrypted Technical Assets: 2 / 2 Risks

Description (Information Disclosure): [CWE 311](#)

Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.

Impact

If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Detection Logic

In-scope unencrypted technical assets (excluding reverse-proxy, load-balancer, waf, ids, ips and embedded components like library) storing data assets rated at least as confidential or critical. For technical assets storing data assets rated as strictly-confidential or mission-critical the encryption must be of type data-with-enduser-individual-key.

Risk Rating

Depending on the confidentiality rating of the stored data-assets either medium or high risk.

False Positives

When all sensitive data stored within the asset is already fully encrypted on document or data level.

Mitigation (Operations): Encryption of Technical Asset

Apply encryption to the technical asset.

ASVS Chapter: [V6 - Stored Cryptography Verification Requirements](#)

Cheat Sheet: [Cryptographic Storage Cheat Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unencrypted Technical Assets** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Unencrypted Technical Asset named **database** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unencrypted-asset@database](#)

Unchecked

Unencrypted Technical Asset named **document-repository** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unencrypted-asset@document-repository](#)

Unchecked

Unnecessary Data Transfer: 4 / 4 Risks

Description (Elevation of Privilege): [CWE 1008](#)

When a technical asset sends or receives data assets, which it neither processes or stores this is an indicator for unnecessarily transferred data (or for an incomplete model). When the unnecessarily transferred data assets are sensitive, this poses an unnecessary risk of an increased attack surface.

Impact

If this risk is unmitigated, attackers might be able to target unnecessarily transferred data.

Detection Logic

In-scope technical assets sending or receiving sensitive data assets which are neither processed nor stored by the technical asset are flagged with this risk. The risk rating (low or medium) depends on the confidentiality, integrity, and availability rating of the technical asset. Monitoring data is exempted from this risk.

Risk Rating

The risk assessment is depending on the confidentiality and integrity rating of the transferred data asset either low or medium.

False Positives

Technical assets missing the model entries of either processing or storing the mentioned data assets can be considered as false positives (incomplete models) after individual review. These should then be addressed by completing the model so that all necessary data assets are processed and/or stored by the technical asset involved.

Mitigation (Architecture): Attack Surface Reduction

Try to avoid sending or receiving sensitive data assets which are not required (i.e. neither processed or stored) by the involved technical asset.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unnecessary Data Transfer** was found **4 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Unnecessary Data Transfer of consent-records data at api-gateway from/to digilocker-backend: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unnecessary-data-transfer@consent-records@api-gateway@digilocker-backend](#)

Unchecked

Unnecessary Data Transfer of digital-signatures data at digilocker-backend from/to issuer-service: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service](#)

Unchecked

Unnecessary Data Transfer of issued-documents data at api-gateway from/to digilocker-backend: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unnecessary-data-transfer@issued-documents@api-gateway@digilocker-backend](#)

Unchecked

Low Risk Severity

Unnecessary Data Transfer of uploaded-documents data at api-gateway from/to digilocker-backend: Exploitation likelihood is *Unlikely* with *Low* impact.

[unnecessary-data-transfer@uploaded-documents@api-gateway@digilocker-backend](#)

Unchecked

DoS-risky Access Across Trust-Boundary: 10 / 10 Risks

Description (Denial of Service): [CWE 400](#)

Assets accessed across trust boundaries with critical or mission-critical availability rating are more prone to Denial-of-Service (DoS) risks.

Impact

If this risk remains unmitigated, attackers might be able to disturb the availability of important parts of the system.

Detection Logic

In-scope technical assets (excluding load-balancer) with availability rating of critical or higher which have incoming data-flows across a network trust-boundary (excluding devops usage).

Risk Rating

Matching technical assets with availability rating of critical or higher are at low risk. When the availability rating is mission-critical and neither a VPN nor IP filter for the incoming data-flow nor redundancy for the asset is applied, the risk-rating is considered medium.

False Positives

When the accessed target operations are not time- or resource-consuming.

Mitigation (Operations): Anti-DoS Measures

Apply anti-DoS techniques like throttling and/or per-client load blocking with quotas. Also for maintenance access routes consider applying a VPN instead of public reachable interfaces. Generally applying redundancy on the targeted technical asset reduces the risk of DoS.

ASVS Chapter: [V1 - Architecture, Design and Threat Modeling Requirements](#)

Cheat Sheet: [Denial_of_Service_Cheat_Sheet](#)

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **DoS-risky Access Across Trust-Boundary** was found **10 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Low Risk Severity

Denial-of-Service risky access of **api-gateway** by **citizen-web-portal** via **Web Portal to API Gateway**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway](#)

Unchecked

Denial-of-Service risky access of **api-gateway** by **mobile-app** via **Mobile App to API Gateway**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway](#)

Unchecked

Denial-of-Service risky access of **authentication-service** by **api-gateway** via **Gateway to Authentication Service**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@authentication-service@api-gateway@api-gateway>gateway-to-authentication-service](#)

Unchecked

Denial-of-Service risky access of **database** by **authentication-service** via **Auth Service to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@database@authentication-service@authentication-service>auth-service-to-database](#)

Unchecked

Denial-of-Service risky access of **database** by **consent-manager** via **Consent Manager to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@database@consent-manager@consent-manager>consent-manager-to-database](#)

Unchecked

Denial-of-Service risky access of **database** by **digilocker-backend** via **Backend to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@database@digilocker-backend@digilocker-backend>backend-to-database](#)

Unchecked

Denial-of-Service risky access of **database** by **monitoring-service** via **Monitoring Service to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@database@monitoring-service@monitoring-service>monitoring-service-to-database](#)

Unchecked

Denial-of-Service risky access of **digilocker-backend** by **api-gateway** via **Gateway to DigiLocker Backend**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Unchecked

Denial-of-Service risky access of **document-repository** by **digilocker-backend** via **Backend to Document Repository**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@document-repository@digilocker-backend@digilocker-backend>backend-to-document-repository

Unchecked

Denial-of-Service risky access of **identity-provider** by **authentication-service** via **Auth Service to Aadhaar Identity Provider**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@identity-provider@authentication-service@authentication-service>auth-service-to-aadhaar-identity-provider

Unchecked

Identified Risks by Technical Asset

In total **74 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 5 as high, 33 as elevated, 25 as medium, and 11 as low.**

These risks are distributed across **13 in-scope technical assets**. The following sub-chapters of this section describe each identified risk grouped by technical asset. The RAA value of a technical asset is the calculated "Relative Attacker Attractiveness" value in percent.

authentication-service: 13 / 13 Risks

Description

Single Sign-On Authentication Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

SQL/NoSQL-Injection risk at **authentication-service** against database **database** via **Auth Service to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

`sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database`

Unchecked

Elevated Risk Severity

Missing Identity Provider Isolation to further encapsulate and protect identity-related asset **authentication-service** against unrelated lower protected assets **in the same network segment**, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Very High* impact.

`missing-identity-provider-isolation@authentication-service`

Unchecked

Cross-Site Scripting (XSS) risk at **authentication-service**: Exploitation likelihood is *Likely* with *High* impact.

`cross-site-scripting@authentication-service`

Unchecked

Cross-Site Request Forgery (CSRF) risk at **authentication-service** via **Gateway to Authentication Service** from **api-gateway**: Exploitation likelihood is *Very Likely* with *Medium* impact.

`cross-site-request-forgery@authentication-service@api-gateway>gateway-to-authentication-service`

Unchecked

Unguarded Access from Internet of **authentication-service** by **api-gateway** via **Gateway to Authentication Service**: Exploitation likelihood is *Very Likely* with *Medium* impact.

`unguarded-access-from-internet@authentication-service@api-gateway>gateway-to-authentication-service`

Unchecked

Missing Hardening risk at **authentication-service**: Exploitation likelihood is *Likely* with *Medium* impact.

missing-hardening@authentication-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **authentication-service** server-side web-requesting the target **identity-provider** via **Auth Service to Aadhaar Identity Provider**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Unchecked

Medium Risk Severity

Container Base Image Backdooring risk at **authentication-service**: Exploitation likelihood is *Unlikely* with *High* impact.

container-baseimage-backdooring@authentication-service

Unchecked

Missing Build Infrastructure in the threat model (referencing asset **authentication-service** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-build-infrastructure@authentication-service

Unchecked

Missing Network Segmentation to further encapsulate and protect **authentication-service** against unrelated lower protected assets in the same network segment, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-network-segmentation@authentication-service

Unchecked

Missing Vault (Secret Storage) in the threat model (referencing asset **authentication-service** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-vault@authentication-service

Unchecked

Missing Web Application Firewall (WAF) risk at **authentication-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-waf@authentication-service

Unchecked

Low Risk Severity

Denial-of-Service risky access of **authentication-service** by **api-gateway** via **Gateway to Authentication Service**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@authentication-service@api-gateway@api-gateway>gateway-to-authentication-service

Unchecked

Asset Information

ID:	authentication-service
Type:	process
Usage:	business
RAA:	100 %
Size:	service
Technology:	identity-provider
Tags:	none
Internet:	false
Machine:	container
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	true
Client by Human:	false
Data Processed:	aadhaar-data, authentication-tokens
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	mission-critical (rated 5 in scale of 5)
Availability:	mission-critical (rated 5 in scale of 5)
CIA-Justification:	

Outgoing Communication Links: 2

Target technical asset names are clickable and link to the corresponding chapter.

Auth Service to Database (outgoing)

Read/write authentication tokens

Target:	database
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials

Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	authentication-tokens
Data Received:	authentication-tokens

Auth Service to Aadhaar Identity Provider (outgoing)

Aadhaar eKYC / OTP verification

Target:	identity-provider
Protocol:	https
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	aadhaar-data
Data Received:	aadhaar-data

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Gateway to Authentication Service (incoming)

Token validation and login handling

Source:	api-gateway
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none

VPN: false
IP-Filtered: false
Data Received: authentication-tokens
Data Sent: authentication-tokens

consent-manager: 5 / 5 Risks

Description

Consent Management Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

SQL/NoSQL-Injection risk at **consent-manager** against database **database** via **Consent Manager to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database

Unchecked

Elevated Risk Severity

Cross-Site Scripting (XSS) risk at **consent-manager**: Exploitation likelihood is *Likely* with *High* impact.

cross-site-scripting@consent-manager

Unchecked

Cross-Site Request Forgery (CSRF) risk at **consent-manager** via **Backend to Consent Manager** from **digilocker-backend**: Exploitation likelihood is *Very Likely* with *Medium* impact.

cross-site-request-forgery@consent-manager@digilocker-backend>backend-to-consent-manager

Unchecked

Medium Risk Severity

Container Base Image Backdooring risk at **consent-manager**: Exploitation likelihood is *Unlikely* with *High* impact.

container-baseimage-backdooring@consent-manager

Unchecked

Missing Enduser Identity Propagation over communication link **Backend to Consent Manager** from **digilocker-backend** to **consent-manager**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-identity-propagation@digilocker-backend>backend-to-consent-manager@digilocker-backend@consent-manager

Unchecked

Asset Information

ID:	consent-manager
Type:	process
Usage:	business
RAA:	16 %
Size:	service
Technology:	application-server
Tags:	none
Internet:	false
Machine:	container
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	true
Client by Human:	false
Data Processed:	consent-records
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

Consent Manager to Database (outgoing)

Store consent records

Target:	database
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business

Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	consent-records
Data Received:	consent-records

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Consent Manager (incoming)

Check and update citizen consent

Source:	digilocker-backend
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	consent-records
Data Sent:	consent-records

digilocker-backend: 16 / 16 Risks

Description

DigiLocker Core Backend

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

SQL/NoSQL-Injection risk at **digilocker-backend** against database **database** via **Backend to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database

Unchecked

SQL/NoSQL-Injection risk at **digilocker-backend** against database **document-repository** via **Backend to Document Repository**: Exploitation likelihood is *Very Likely* with *High* impact.

sql-nosql-injection@digilocker-backend@document-repository@digilocker-backend>backend-to-document-repository

Unchecked

Elevated Risk Severity

Cross-Site Scripting (XSS) risk at **digilocker-backend**: Exploitation likelihood is *Likely* with *High* impact.

cross-site-scripting@digilocker-backend

Unchecked

Cross-Site Request Forgery (CSRF) risk at **digilocker-backend** via **Gateway to DigiLocker Backend** from **api-gateway**: Exploitation likelihood is *Very Likely* with *Medium* impact.

cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Unchecked

Unguarded Access from Internet of **digilocker-backend** by **api-gateway** via **Gateway to DigiLocker Backend**: Exploitation likelihood is *Very Likely* with *Medium* impact.

unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Unchecked

Missing Hardening risk at **digilocker-backend**: Exploitation likelihood is *Likely* with *Medium* impact.

missing-hardening@digilocker-backend

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **consent-manager** via **Backend to Consent Manager**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **issuer-service** via **Backend to Issuer Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **monitoring-service** via **Backend to Monitoring Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **notification-service** via **Backend to Notification Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Unchecked

Server-Side Request Forgery (SSRF) risk at **digilocker-backend** server-side web-requesting the target **requester-service** via **Backend to Requester Service**: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Unchecked

Medium Risk Severity

Container Base Image Backdooring risk at **digilocker-backend**: Exploitation likelihood is *Unlikely* with *High* impact.

container-baseimage-backdooring@digilocker-backend

Unchecked

Missing Identity Store in the threat model (referencing asset **digilocker-backend** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-identity-store@digilocker-backend

Unchecked

Missing Web Application Firewall (WAF) risk at **digilocker-backend**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-waf@digilocker-backend

Unchecked

Unnecessary Data Transfer of **digital-signatures** data at **digilocker-backend** from/to **issuer-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service

Unchecked

Low Risk Severity

Denial-of-Service risky access of **digilocker-backend** by **api-gateway** via **Gateway to DigiLocker Backend**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Unchecked

Asset Information

ID:	digilocker-backend
Type:	process
Usage:	business
RAA:	85 %
Size:	application
Technology:	application-server
Tags:	none
Internet:	false
Machine:	container
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	true
Client by Human:	false
Data Processed:	authentication-tokens, citizen-profile, consent-records, issued-documents, uploaded-documents
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	mission-critical	(rated 5 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 7

Target technical asset names are clickable and link to the corresponding chapter.

Backend to Requester Service (outgoing)

Share verified documents with requesting parties

Target:	requester-service
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	issued-documents
Data Received:	none

Backend to Notification Service (outgoing)

Trigger email/SMS notifications to citizens

Target:	notification-service
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	citizen-profile
Data Received:	none

Backend to Monitoring Service (outgoing)

Emit audit and security events

Target:	monitoring-service
Protocol:	https

Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	audit-logs
Data Received:	none

Backend to Issuer Service (outgoing)

Fetch issued documents and digital signatures

Target:	issuer-service
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	true
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	none
Data Received:	digital-signatures, issued-documents

Backend to Document Repository (outgoing)

Store and retrieve issued and uploaded documents

Target:	document-repository
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false

Data Sent: issued-documents, uploaded-documents

Data Received: issued-documents, uploaded-documents

Backend to Database (outgoing)

Read/write citizen profile and consent records

Target: database

Protocol: jdbc-encrypted

Encrypted: true

Authentication: credentials

Authorization: technical-user

Read-Only: false

Usage: business

Tags: none

VPN: false

IP-Filtered: false

Data Sent: citizen-profile, consent-records

Data Received: citizen-profile, consent-records

Backend to Consent Manager (outgoing)

Check and update citizen consent

Target: consent-manager

Protocol: https

Encrypted: true

Authentication: token

Authorization: technical-user

Read-Only: false

Usage: business

Tags: none

VPN: false

IP-Filtered: false

Data Sent: consent-records

Data Received: consent-records

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Gateway to DigiLocker Backend (incoming)

Business API calls to the core backend

Source:	api-gateway
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	authentication-tokens, citizen-profile
Data Sent:	citizen-profile, consent-records, issued-documents, uploaded-documents

monitoring-service: 2 / 2 Risks

Description

Monitoring and Audit Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

SQL/NoSQL-Injection risk at **monitoring-service** against database **database** via **Monitoring Service to Database**: Exploitation likelihood is *Very Likely* with *High* impact.

[sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database](#)

Unchecked

Medium Risk Severity

Container Base Image Backdooring risk at **monitoring-service**: Exploitation likelihood is *Unlikely* with *High* impact.

[container-baseimage-backdooring@monitoring-service](#)

Unchecked

Asset Information

ID:	monitoring-service
Type:	process
Usage:	business
RAA:	1 %
Size:	service
Technology:	monitoring
Tags:	none
Internet:	false
Machine:	container
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	audit-logs
Data Stored:	none

Formats Accepted: none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	internal	(rated 2 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

Monitoring Service to Database (outgoing)

Persist audit logs

Target:	database
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	audit-logs
Data Received:	audit-logs

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Monitoring Service (incoming)

Emit audit and security events

Source:	digilocker-backend
Protocol:	https
Encrypted:	true

Authentication: token
Authorization: technical-user
Read-Only: false
Usage: business
Tags: none
VPN: false
IP-Filtered: false
Data Received: audit-logs
Data Sent: none

api-gateway: 12 / 12 Risks

Description

API Gateway

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unguarded Access from Internet of api-gateway by citizen-web-portal via Web Portal to API Gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

unguarded-access-from-internet@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway

Unchecked

Unguarded Access from Internet of api-gateway by mobile-app via Mobile App to API Gateway: Exploitation likelihood is *Very Likely* with *Medium* impact.

unguarded-access-from-internet@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway

Unchecked

Server-Side Request Forgery (SSRF) risk at api-gateway server-side web-requesting the target authentication-service via Gateway to Authentication Service: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@api-gateway@authentication-service@api-gateway>gateway-to-authentication-service

Unchecked

Server-Side Request Forgery (SSRF) risk at api-gateway server-side web-requesting the target digilocker-backend via Gateway to DigiLocker Backend: Exploitation likelihood is *Likely* with *Medium* impact.

server-side-request-forgery@api-gateway@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Unchecked

Medium Risk Severity

Container Base Image Backdooring risk at api-gateway: Exploitation likelihood is *Unlikely* with *High* impact.

container-baseimage-backdooring@api-gateway

Unchecked

Missing Two-Factor Authentication covering communication link Mobile App to API Gateway from mobile-app to api-gateway: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-authentication-second-factor@mobile-app>mobile-app-to-api-gateway@mobile-app@api-gateway

Unchecked

Missing Two-Factor Authentication covering communication link **Web Portal to API Gateway** from **citizen-web-portal** to **api-gateway**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-authentication-second-factor@citizen-web-portal>web-portal-to-api-gateway@citizen-web-portal@api-gateway

Unchecked

Unnecessary Data Transfer of **consent-records** data at **api-gateway** from/to **digilocker-backend**: Exploitation likelihood is *Unlikely* with *Medium* impact.

unnecessary-data-transfer@consent-records@api-gateway@digilocker-backend

Unchecked

Unnecessary Data Transfer of **issued-documents** data at **api-gateway** from/to **digilocker-backend**: Exploitation likelihood is *Unlikely* with *Medium* impact.

unnecessary-data-transfer@issued-documents@api-gateway@digilocker-backend

Unchecked

Low Risk Severity

Denial-of-Service risky access of **api-gateway** by **citizen-web-portal** via **Web Portal to API Gateway**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway

Unchecked

Denial-of-Service risky access of **api-gateway** by **mobile-app** via **Mobile App to API Gateway**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway

Unchecked

Unnecessary Data Transfer of **uploaded-documents** data at **api-gateway** from/to **digilocker-backend**: Exploitation likelihood is *Unlikely* with *Low* impact.

unnecessary-data-transfer@uploaded-documents@api-gateway@digilocker-backend

Unchecked

Asset Information

ID:	api-gateway
Type:	process
Usage:	business
RAA:	46 %
Size:	service
Technology:	gateway
Tags:	none
Internet:	true
Machine:	container
Encryption:	transparent

Multi-Tenant:	false
Redundant:	true
Custom-Developed:	true
Client by Human:	false
Data Processed:	authentication-tokens, citizen-profile
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	mission-critical	(rated 5 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 2

Target technical asset names are clickable and link to the corresponding chapter.

Gateway to DigiLocker Backend (outgoing)

Business API calls to the core backend

Target:	digilocker-backend
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	authentication-tokens, citizen-profile
Data Received:	citizen-profile, consent-records, issued-documents, uploaded-documents

Gateway to Authentication Service (outgoing)

Token validation and login handling

Target:	authentication-service
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	authentication-tokens
Data Received:	authentication-tokens

Incoming Communication Links: 2

Source technical asset names are clickable and link to the corresponding chapter.

Mobile App to API Gateway (incoming)

Mobile app calling the platform API

Source:	mobile-app
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	authentication-tokens
Data Sent:	authentication-tokens, citizen-profile

Web Portal to API Gateway (incoming)

Citizen browser session calling the platform API

Source:	citizen-web-portal
Protocol:	https
Encrypted:	true
Authentication:	session-id

Authorization: enduser-identity-propagation
Read-Only: false
Usage: business
Tags: none
VPN: false
IP-Filtered: false
Data Received: authentication-tokens
Data Sent: authentication-tokens, citizen-profile

citizen-web-portal: 2 / 2 Risks

Description

DigiLocker Citizen Web Portal

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Cross-Site Scripting (XSS) risk at **citizen-web-portal**: Exploitation likelihood is *Likely* with *High* impact.

`cross-site-scripting@citizen-web-portal`

Unchecked

Server-Side Request Forgery (SSRF) risk at **citizen-web-portal** server-side web-requesting the target **api-gateway** via **Web Portal to API Gateway**: Exploitation likelihood is *Likely* with *Medium* impact.

`server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway`

Unchecked

Asset Information

ID:	citizen-web-portal
Type:	process
Usage:	business
RAA:	26 %
Size:	application
Technology:	web-application
Tags:	none
Internet:	true
Machine:	virtual
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	true
Client by Human:	true
Data Processed:	authentication-tokens, citizen-profile
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

Web Portal to API Gateway (outgoing)

Citizen browser session calling the platform API

Target:	api-gateway
Protocol:	https
Encrypted:	true
Authentication:	session-id
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	authentication-tokens
Data Received:	authentication-tokens, citizen-profile

database: 10 / 10 Risks

Description

DigiLocker Relational Database

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Hardening risk at **database**: Exploitation likelihood is *Likely* with *Medium* impact.

[missing-hardening@database](#)

Unchecked

Unguarded Direct Datastore Access of database by authentication-service via Auth Service to Database: Exploitation likelihood is *Likely* with *Medium* impact.

[unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database](#)

Unchecked

Unguarded Direct Datastore Access of database by consent-manager via Consent Manager to Database: Exploitation likelihood is *Likely* with *Medium* impact.

[unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database](#)

Unchecked

Unguarded Direct Datastore Access of database by digilocker-backend via Backend to Database: Exploitation likelihood is *Likely* with *Medium* impact.

[unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database](#)

Unchecked

Unguarded Direct Datastore Access of database by monitoring-service via Monitoring Service to Database: Exploitation likelihood is *Likely* with *Medium* impact.

[unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database](#)

Unchecked

Medium Risk Severity

Unencrypted Technical Asset named **database** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unencrypted-asset@database](#)

Unchecked

Low Risk Severity

Denial-of-Service risky access of **database** by **authentication-service** via **Auth Service to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@database@authentication-service@authentication-service>auth-service-to-database

Unchecked

Denial-of-Service risky access of **database** by **consent-manager** via **Consent Manager to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@database@consent-manager@consent-manager>consent-manager-to-database

Unchecked

Denial-of-Service risky access of **database** by **digilocker-backend** via **Backend to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@database@digilocker-backend@digilocker-backend>backend-to-database

Unchecked

Denial-of-Service risky access of **database** by **monitoring-service** via **Monitoring Service to Database**: Exploitation likelihood is *Unlikely* with *Low* impact.

dos-risky-access-across-trust-boundary@database@monitoring-service@monitoring-service>monitoring-service-to-database

Unchecked

Asset Information

ID:	database
Type:	datastore
Usage:	business
RAA:	60 %
Size:	component
Technology:	database
Tags:	none
Internet:	false
Machine:	virtual
Encryption:	data-with-symmetric-shared-key
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	none
Data Stored:	audit-logs, authentication-tokens, citizen-profile, consent-records
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	mission-critical	(rated 5 in scale of 5)
CIA-Justification:		

Incoming Communication Links: 4

Source technical asset names are clickable and link to the corresponding chapter.

Monitoring Service to Database (incoming)

Persist audit logs

Source:	monitoring-service
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	audit-logs
Data Sent:	audit-logs

Backend to Database (incoming)

Read/write citizen profile and consent records

Source:	digilocker-backend
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false

IP-Filtered: false
 Data Received: citizen-profile, consent-records
 Data Sent: citizen-profile, consent-records

Consent Manager to Database (incoming)

Store consent records

Source: consent-manager
 Protocol: jdbc-encrypted
 Encrypted: true
 Authentication: credentials
 Authorization: technical-user
 Read-Only: false
 Usage: business
 Tags: none
 VPN: false
 IP-Filtered: false
 Data Received: consent-records
 Data Sent: consent-records

Auth Service to Database (incoming)

Read/write authentication tokens

Source: authentication-service
 Protocol: jdbc-encrypted
 Encrypted: true
 Authentication: credentials
 Authorization: technical-user
 Read-Only: false
 Usage: business
 Tags: none
 VPN: false
 IP-Filtered: false
 Data Received: authentication-tokens
 Data Sent: authentication-tokens

document-repository: 3 / 3 Risks

Description

Secure Document Repository

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unguarded Direct Datastore Access of document-repository by digilocker-backend via Backend to Document Repository: Exploitation likelihood is *Likely* with *Medium* impact.

[unguarded-direct-datastore-access@digilocker-backend>backend-to-document-repository@digilocker-backend@document-repository](#)

Unchecked

Medium Risk Severity

Unencrypted Technical Asset named **document-repository** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *Medium* impact.

[unencrypted-asset@document-repository](#)

Unchecked

Low Risk Severity

Denial-of-Service risky access of **document-repository** by **digilocker-backend** via **Backend to Document Repository**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@document-repository@digilocker-backend@digilocker-backend>backend-to-document-repository](#)

Unchecked

Asset Information

ID:	document-repository
Type:	datastore
Usage:	business
RAA:	33 %
Size:	component
Technology:	database
Tags:	none
Internet:	false

Machine:	virtual
Encryption:	data-with-symmetric-shared-key
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	none
Data Stored:	issued-documents, uploaded-documents
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	mission-critical	(rated 5 in scale of 5)
CIA-Justification:		

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Document Repository (incoming)

Store and retrieve issued and uploaded documents

Source:	digilocker-backend
Protocol:	jdbc-encrypted
Encrypted:	true
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	issued-documents, uploaded-documents
Data Sent:	issued-documents, uploaded-documents

identity-provider: 5 / 5 Risks

Description

Aadhaar Identity Provider

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Identity Provider Isolation to further encapsulate and protect identity-related asset **identity-provider** against unrelated lower protected assets **in the same network segment**, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Very High* impact.

[missing-identity-provider-isolation@identity-provider](#)

Unchecked

Cross-Site Scripting (XSS) risk at **identity-provider**: Exploitation likelihood is *Likely* with *High* impact.

[cross-site-scripting@identity-provider](#)

Unchecked

Cross-Site Request Forgery (CSRF) risk at **identity-provider** via **Auth Service to Aadhaar Identity Provider** from **authentication-service**: Exploitation likelihood is *Very Likely* with *Medium* impact.

[cross-site-request-forgery@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider](#)

Unchecked

Medium Risk Severity

Missing Web Application Firewall (WAF) risk at **identity-provider**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@identity-provider](#)

Unchecked

Low Risk Severity

Denial-of-Service risky access of **identity-provider** by **authentication-service** via **Auth Service to Aadhaar Identity Provider**: Exploitation likelihood is *Unlikely* with *Low* impact.

[dos-risky-access-across-trust-boundary@identity-provider@authentication-service@authentication-service>auth-service-to-aadhaar-identity-provider](#)

Unchecked

Asset Information

ID:	identity-provider
Type:	external-entity
Usage:	business
RAA:	35 %
Size:	system
Technology:	identity-provider
Tags:	none
Internet:	false
Machine:	virtual
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	aadhaar-data
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	UIDAI	
Confidentiality:	strictly-confidential	(rated 5 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	mission-critical	(rated 5 in scale of 5)
CIA-Justification:		

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Auth Service to Aadhaar Identity Provider (incoming) Aadhaar eKYC / OTP verification

Source:	authentication-service
Protocol:	https
Encrypted:	true
Authentication:	credentials

Authorization: technical-user
Read-Only: false
Usage: business
Tags: none
VPN: false
IP-Filtered: false
Data Received: aadhaar-data
Data Sent: aadhaar-data

issuer-service: 2 / 2 Risks

Description

Government Issuer Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Enduser Identity Propagation over communication link **Backend to Issuer Service** from **digilocker-backend** to **issuer-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-propagation@digilocker-backend>backend-to-issuer-service@digilocker-backend@issuer-service](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **issuer-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@issuer-service](#)

Unchecked

Asset Information

ID:	issuer-service
Type:	external-entity
Usage:	business
RAA:	16 %
Size:	system
Technology:	web-service-rest
Tags:	none
Internet:	false
Machine:	virtual
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	digital-signatures, issued-documents
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	Government	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Issuer Service (incoming)

Fetch issued documents and digital signatures

Source:	digilocker-backend
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	true
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	none
Data Sent:	digital-signatures, issued-documents

notification-service: 1 / 1 Risk

Description

Email and SMS Notification Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Container Base Image Backdooring risk at **notification-service**: Exploitation likelihood is *Unlikely with Medium impact*.

[container-baseimage-backdooring@notification-service](#)

Unchecked

Asset Information

ID:	notification-service
Type:	process
Usage:	business
RAA:	5 %
Size:	service
Technology:	message-queue
Tags:	none
Internet:	true
Machine:	container
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	citizen-profile
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	internal	(rated 2 in scale of 5)

Integrity: important (rated 3 in scale of 5)
Availability: important (rated 3 in scale of 5)
CIA-Justification:

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Notification Service (incoming)

Trigger email/SMS notifications to citizens

Source: digilocker-backend
Protocol: https
Encrypted: true
Authentication: token
Authorization: technical-user
Read-Only: false
Usage: business
Tags: none
VPN: false
IP-Filtered: false
Data Received: citizen-profile
Data Sent: none

requester-service: 2 / 2 Risks

Description

Requester Verification Service

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Enduser Identity Propagation over communication link **Backend to Requester Service** from **digilocker-backend** to **requester-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-identity-propagation@digilocker-backend>backend-to-requester-service@digilocker-backend@requester-service](#)

Unchecked

Missing Web Application Firewall (WAF) risk at **requester-service**: Exploitation likelihood is *Unlikely* with *Medium* impact.

[missing-waf@requester-service](#)

Unchecked

Asset Information

ID:	requester-service
Type:	external-entity
Usage:	business
RAA:	9 %
Size:	system
Technology:	web-service-rest
Tags:	none
Internet:	false
Machine:	virtual
Encryption:	transparent
Multi-Tenant:	false
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	issued-documents
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	Requester	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Backend to Requester Service (incoming)

Share verified documents with requesting parties

Source:	digilocker-backend
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	issued-documents
Data Sent:	none

mobile-app: 0 / 0 Risks

Description

DigiLocker Mobile Application

Identified Risks of Asset

No risks were identified.

Asset Information

ID:	mobile-app
Type:	process
Usage:	business
RAA:	26 %
Size:	application
Technology:	mobile-app
Tags:	none
Internet:	true
Machine:	physical
Encryption:	transparent
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	true
Client by Human:	true
Data Processed:	authentication-tokens, citizen-profile
Data Stored:	none
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:		

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

Mobile App to API Gateway (outgoing)

Mobile app calling the platform API

Target:	api-gateway
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	authentication-tokens
Data Received:	authentication-tokens, citizen-profile

Identified Data Breach Probabilities by Data Asset

In total **74 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 5 as high, 33 as elevated, 25 as medium, and 11 as low.**

These risks are distributed across **8 data assets**. The following sub-chapters of this section describe the derived data breach probabilities grouped by data asset.

Technical asset names and risk IDs are clickable and link to the corresponding chapter.

aadhaar-data: 19 / 19 Risks

Aadhaar identity information

ID:	aadhaar-data
Usage:	business
Quantity:	many
Tags:	none
Origin:	Identity Provider
Owner:	UIDAI
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	mission-critical (rated 5 in scale of 5)
Availability:	important (rated 3 in scale of 5)
CIA-Justification:	Sensitive citizen identity information.
Processed by:	authentication-service, identity-provider
Stored by:	none
Sent via:	Auth Service to Aadhaar Identity Provider
Received via:	Auth Service to Aadhaar Identity Provider
Data Breach:	probable
Data Breach Risks:	This data asset has data breach potential because of 19 remaining risks:

Probable: container-baseimage-backdooring@authentication-service

Possible: cross-site-scripting@authentication-service

Possible: cross-site-scripting@identity-provider

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: unguarded-access-from-internet@authentication-service@api-gateway@api-gateway>gateway-to-authentication-service

Improbable: cross-site-request-forgery@authentication-service@api-gateway>gateway-to-authentication-service

Improbable: cross-site-request-forgery@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Improbable: missing-hardening@authentication-service

Improbable: missing-identity-provider-isolation@authentication-service

Improbable: missing-identity-provider-isolation@identity-provider

Improbable: missing-network-segmentation@authentication-service

Improbable: missing-waf@authentication-service

Improbable: missing-waf@identity-provider

audit-logs: 17 / 17 Risks

Security audit logs

ID:	audit-logs
Usage:	business
Quantity:	many
Tags:	none
Origin:	Monitoring
Owner:	DigiLocker
Confidentiality:	internal (rated 2 in scale of 5)
Integrity:	mission-critical (rated 5 in scale of 5)
Availability:	important (rated 3 in scale of 5)
CIA-Justification:	Security investigation records.
Processed by:	monitoring-service
Stored by:	database
Sent via:	Monitoring Service to Database, Backend to Monitoring Service
Received via:	Monitoring Service to Database
Data Breach:	probable
Data Breach Risks:	This data asset has data breach potential because of 17 remaining risks:

Probable: container-baseimage-backdooring@monitoring-service

Probable: sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database

Probable: sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database

Probable: sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database

Probable: sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Improbable: missing-hardening@database

Improbable: unencrypted-asset@database

Improbable: unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database

Improbable: unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database

Improbable: unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database

Improbable: unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database

authentication-tokens: 44 / 44 Risks

Session tokens

ID:	authentication-tokens
Usage:	business
Quantity:	many
Tags:	none
Origin:	Authentication Service
Owner:	DigiLocker
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	mission-critical (rated 5 in scale of 5)
Availability:	important (rated 3 in scale of 5)
CIA-Justification:	Used for authentication.
Processed by:	api-gateway, authentication-service, citizen-web-portal, digilocker-backend, mobile-app
Stored by:	database
Sent via:	Web Portal to API Gateway, Mobile App to API Gateway, Gateway to DigiLocker Backend, Gateway to Authentication Service, Auth Service to Database
Received via:	Web Portal to API Gateway, Mobile App to API Gateway, Gateway to Authentication Service, Auth Service to Database

Data Breach: **probable**

Data Breach Risks: This data asset has data breach potential because of 44 remaining risks:

Probable: container-baseimage-backdooring@api-gateway

Probable: container-baseimage-backdooring@authentication-service

Probable: container-baseimage-backdooring@digilocker-backend

Probable: missing-cloud-hardening@dmz

Probable: sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database

Probable: sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database

Probable: sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database

Probable: sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database

Possible: cross-site-scripting@authentication-service

Possible: cross-site-scripting@citizen-web-portal

Possible: cross-site-scripting@digilocker-backend

Possible: missing-authentication-second-factor@mobile-app>mobile-app-to-api-gateway@mobile-app@api-gateway

Possible: missing-authentication-second-factor@citizen-web-portal>web-portal-to-api-gateway@citizen-web-portal@api-gateway

Possible: server-side-request-forgery@api-gateway@authentication-service@api-gateway>gateway-to-authentication-service

Possible: server-side-request-forgery@api-gateway@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: unguarded-access-from-internet@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway

Possible: unguarded-access-from-internet@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway

Possible: unguarded-access-from-internet@authentication-service@api-gateway@api-gateway>gateway-to-authentication-service

Possible: unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Improbable: cross-site-request-forgery@authentication-service@api-gateway>gateway-to-authentication-service

Improbable: cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Improbable: missing-hardening@authentication-service

Improbable: missing-hardening@database

Improbable: missing-hardening@digilocker-backend

Improbable: missing-identity-provider-isolation@authentication-service

Improbable: missing-network-segmentation@authentication-service

Improbable: missing-waf@authentication-service

Improbable: missing-waf@digilocker-backend

Improbable: unencrypted-asset@database

Improbable: unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database

Improbable: unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database

Improbable: unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database

Improbable: unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database

Improbable: unnecessary-data-transfer@consent-records@api-gateway@digilocker-backend

Improbable: unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service

Improbable: unnecessary-data-transfer@issued-documents@api-gateway@digilocker-backend

Improbable: unnecessary-data-transfer@uploaded-documents@api-gateway@digilocker-backend

citizen-profile: 37 / 37 Risks

Citizen personal profile

ID:	citizen-profile	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	Citizen	
Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Contains citizen personal information.	
Processed by:	api-gateway, citizen-web-portal, digilocker-backend, mobile-app, notification-service	
Stored by:	database	
Sent via:	Gateway to DigiLocker Backend, Backend to Notification Service, Backend to Database	
Received via:	Web Portal to API Gateway, Mobile App to API Gateway, Gateway to DigiLocker Backend, Backend to Database	
Data Breach:	probable	
Data Breach Risks:	This data asset has data breach potential because of 37 remaining risks:	

Probable: container-baseimage-backdooring@api-gateway

Probable: container-baseimage-backdooring@digilocker-backend

Probable: container-baseimage-backdooring@notification-service

Probable: missing-cloud-hardening@dmz

Probable: sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database

Probable: sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database

Probable: sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database

Probable: sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database

Possible: cross-site-scripting@citizen-web-portal

Possible: cross-site-scripting@digilocker-backend

Possible: missing-authentication-second-factor@mobile-app>mobile-app-to-api-gateway@mobile-app@api-gateway

Possible: missing-authentication-second-factor@citizen-web-portal>web-portal-to-api-gateway@citizen-web-portal@api-gateway

Possible: server-side-request-forgery@api-gateway@authentication-service@api-gateway>gateway-to-authentication-service

Possible: server-side-request-forgery@api-gateway@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: `unguarded-access-from-internet@api-gateway@citizen-web-portal@citizen-web-portal>web-portal-to-api-gateway`

Possible: `unguarded-access-from-internet@api-gateway@mobile-app@mobile-app>mobile-app-to-api-gateway`

Possible: `unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend`

Improbable: `cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend`

Improbable: `missing-hardening@database`

Improbable: `missing-hardening@digilocker-backend`

Improbable: `missing-waf@digilocker-backend`

Improbable: `unencrypted-asset@database`

Improbable: `unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database`

Improbable: `unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database`

Improbable: `unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database`

Improbable: `unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database`

Improbable: `unnecessary-data-transfer@consent-records@api-gateway@digilocker-backend`

Improbable: `unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service`

Improbable: `unnecessary-data-transfer@issued-documents@api-gateway@digilocker-backend`

Improbable: `unnecessary-data-transfer@uploaded-documents@api-gateway@digilocker-backend`

consent-records: 27 / 27 Risks

Consent history

ID:	consent-records	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	Consent Manager	
Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Legal consent information.	
Processed by:	consent-manager, digilocker-backend	
Stored by:	database	
Sent via:	Consent Manager to Database, Backend to Database, Backend to Consent Manager	
Received via:	Gateway to DigiLocker Backend, Consent Manager to Database, Backend to Database, Backend to Consent Manager	
Data Breach:	probable	
Data Breach Risks:	This data asset has data breach potential because of 27 remaining risks:	

Probable: container-baseimage-backdooring@consent-manager

Probable: container-baseimage-backdooring@digilocker-backend

Probable: sql-nosql-injection@authentication-service@database@authentication-service>auth-service-to-database

Probable: sql-nosql-injection@consent-manager@database@consent-manager>consent-manager-to-database

Probable: sql-nosql-injection@digilocker-backend@database@digilocker-backend>backend-to-database

Probable: sql-nosql-injection@monitoring-service@database@monitoring-service>monitoring-service-to-database

Possible: cross-site-scripting@consent-manager

Possible: cross-site-scripting@digilocker-backend

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Improbable: cross-site-request-forgery@consent-manager@digilocker-backend>backend-to-consent-manager

Improbable: cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Improbable: missing-identity-propagation@digilocker-backend>backend-to-consent-manager@digilocker-backend@consent-manager

Improbable: missing-hardening@database

Improbable: missing-hardening@digilocker-backend

Improbable: missing-waf@digilocker-backend

Improbable: unencrypted-asset@database

Improbable: unguarded-direct-datastore-access@authentication-service>auth-service-to-database@authentication-service@database

Improbable: unguarded-direct-datastore-access@consent-manager>consent-manager-to-database@consent-manager@database

Improbable: unguarded-direct-datastore-access@digilocker-backend>backend-to-database@digilocker-backend@database

Improbable: unguarded-direct-datastore-access@monitoring-service>monitoring-service-to-database@monitoring-service@database

Improbable: unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service

issued-documents: 21 / 21 Risks

Government issued certificates

ID:	issued-documents
Usage:	business
Quantity:	many
Tags:	none
Origin:	Issuer
Owner:	DigiLocker
Confidentiality:	confidential (rated 4 in scale of 5)
Integrity:	mission-critical (rated 5 in scale of 5)
Availability:	mission-critical (rated 5 in scale of 5)
CIA-Justification:	Official certificates and records.
Processed by:	digilocker-backend, issuer-service, requester-service
Stored by:	document-repository
Sent via:	Backend to Requester Service, Backend to Document Repository
Received via:	Gateway to DigiLocker Backend, Backend to Issuer Service, Backend to Document Repository

Data Breach: **probable**

Data Breach Risks: This data asset has data breach potential because of 21 remaining risks:

Probable: container-baseimage-backdooring@digilocker-backend

Probable: sql-nosql-injection@digilocker-backend@document-repository@digilocker-backend>backend-to-document-repository

Possible: cross-site-scripting@digilocker-backend

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Improbable: cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Improbable: missing-identity-propagation@digilocker-backend>backend-to-issuer-service@digilocker-backend@issuer-service

Improbable: missing-identity-propagation@digilocker-backend>backend-to-requester-service@digilocker-backend@requester-service

Improbable: missing-hardening@digilocker-backend

Improbable: missing-waf@digilocker-backend

Improbable: missing-waf@issuer-service

Improbable: missing-waf@requester-service

Improbable: unencrypted-asset@document-repository

Improbable: unguarded-direct-datastore-access@digilocker-backend>backend-to-document-repository@digilocker-backend@document-repository

Improbable: unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service

uploaded-documents: 16 / 16 Risks

User uploaded files

ID:	uploaded-documents	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	Citizen	
Owner:	Citizen	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Personal uploaded files.	
Processed by:	digilocker-backend	
Stored by:	document-repository	
Sent via:	Backend to Document Repository	
Received via:	Gateway to DigiLocker Backend, Backend to Document Repository	
Data Breach:	probable	
Data Breach Risks:	This data asset has data breach potential because of 16 remaining risks:	

Probable: container-baseimage-backdooring@digilocker-backend

Probable: sql-nosql-injection@digilocker-backend@document-repository@digilocker-backend>backend-to-document-repository

Possible: cross-site-scripting@digilocker-backend

Possible: server-side-request-forgery@authentication-service@identity-provider@authentication-service>auth-service-to-aadhaar-identity-provider

Possible: server-side-request-forgery@digilocker-backend@consent-manager@digilocker-backend>backend-to-consent-manager

Possible: server-side-request-forgery@digilocker-backend@issuer-service@digilocker-backend>backend-to-issuer-service

Possible: server-side-request-forgery@digilocker-backend@monitoring-service@digilocker-backend>backend-to-monitoring-service

Possible: server-side-request-forgery@digilocker-backend@notification-service@digilocker-backend>backend-to-notification-service

Possible: server-side-request-forgery@digilocker-backend@requester-service@digilocker-backend>backend-to-requester-service

Possible: unguarded-access-from-internet@digilocker-backend@api-gateway@api-gateway>gateway-to-digilocker-backend

Improbable: cross-site-request-forgery@digilocker-backend@api-gateway>gateway-to-digilocker-backend

Improbable: missing-hardening@digilocker-backend

Improbable: missing-waf@digilocker-backend

Improbable: unencrypted-asset@document-repository

Improbable: unguarded-direct-datastore-access@digilocker-backend>backend-to-document-repository@digilocker-backend@document-repository

Improbable: unnecessary-data-transfer@digital-signatures@digilocker-backend@issuer-service

digital-signatures: 3 / 3 Risks

Digital signature information

ID:	digital-signatures	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	Issuer	
Owner:	DigiLocker	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	mission-critical	(rated 5 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Digital signatures for document verification.	
Processed by:	issuer-service	
Stored by:	none	
Sent via:	none	
Received via:	Backend to Issuer Service	
Data Breach:	possible	
Data Breach Risks:	This data asset has data breach potential because of 3 remaining risks:	

Possible: [server-side-request-forgery@citizen-web-portal@api-gateway@citizen-web-portal>web-portal-to-api-gateway](#)

Improbable: [missing-identity-propagation@digilocker-backend>backend-to-issuer-service@digilocker-backend@issuer-service](#)

Improbable: [missing-waf@issuer-service](#)

Trust Boundaries

In total **3 trust boundaries** have been modeled during the threat modeling process.

Application Zone

Internal application and business services

ID: application-zone
Type: [network-virtual-lan](#)
Tags: none
Assets inside: authentication-service, consent-manager, digilocker-backend, monitoring-service
Boundaries nested: none

DMZ

Internet-facing edge services

ID: dmz
Type: [network-cloud-security-group](#)
Tags: none
Assets inside: api-gateway, notification-service
Boundaries nested: none

Data Zone

Persistent storage tier

ID: data-zone
Type: [network-virtual-lan](#)
Tags: none
Assets inside: database, document-repository
Boundaries nested: none

Shared Runtimes

In total **0 shared runtime** has been modeled during the threat modeling process.

Risk Rules Checked by Threagile

Threagile Version: 1.0.0

Threagile Build Timestamp: 20240730113903

Threagile Execution Timestamp: 20260724192329

Model Filename: /app/work/digilocker.yaml

Model Hash (SHA256): 98f5430677330051c83d97b0462600619a825f36c27e1bf81c252cd603188287

Threagile (see <https://threagile.io> for more details) is an open-source toolkit for agile threat modeling, created by Christian Schneider (<https://christian-schneider.net>): It allows to model an architecture with its assets in an agile fashion as a YAML file directly inside the IDE. Upon execution of the Threagile toolkit all standard risk rules (as well as individual custom rules if present) are checked against the architecture model. At the time the Threagile toolkit was executed on the model input file the following risk rules were checked:

Accidental Secret Leak

accidental-secret-leak

STRIDE: Information Disclosure

Description: Sourcecode repositories (including their histories) as well as artifact registries can accidentally contain secrets like checked-in or packaged-in passwords, API tokens, certificates, crypto keys, etc.

Detection: In-scope sourcecode repositories and artifact registries.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Code Backdooring

code-backdooring

STRIDE: Tampering

Description: For each build-pipeline component Code Backdooring risks might arise where attackers compromise the build-pipeline in order to let backdoored artifacts be shipped into production. Aside from direct code backdooring this includes backdooring of dependencies and even of more lower-level build infrastructure, like backdooring compilers (similar to what the XcodeGhost malware did) or dependencies.

Detection: In-scope development relevant technical assets which are either accessed by out-of-scope unmanaged developer clients and/or are directly accessed by any kind of internet-located (non-VPN) component or are themselves directly located on the internet.

Rating: The risk rating depends on the confidentiality and integrity rating of the code being handled and deployed as well as the placement/calling of this technical asset on/from the internet.

Container Base Image Backdooring

container-baseimage-backdooring

STRIDE: Tampering

Description: When a technical asset is built using container technologies, Base Image Backdooring risks might arise where base images and other layers used contain vulnerable components or backdoors.

Detection: In-scope technical assets running as containers.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets.

Container Platform Escape

container-platform-escape

STRIDE: Elevation of Privilege

Description: Container platforms are especially interesting targets for attackers as they host big parts of a containerized runtime infrastructure. When not configured and operated with security best practices in mind, attackers might exploit a vulnerability inside an container and escape towards the platform as highly privileged users. These scenarios might give attackers capabilities to attack every other container as owning the container platform (via container escape attacks) equals to owning every container.

Detection: In-scope container platforms.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Cross-Site Request Forgery (CSRF)

cross-site-request-forgery

STRIDE: Spoofing

Description: When a web application is accessed via web protocols Cross-Site Request Forgery (CSRF) risks might arise.

Detection: In-scope web applications accessed via typical web access protocols.

Rating: The risk rating depends on the integrity rating of the data sent across the communication link.

Cross-Site Scripting (XSS)

cross-site-scripting

STRIDE: Tampering

Description: For each web application Cross-Site Scripting (XSS) risks might arise. In terms of the overall risk level take other applications running on the same domain into account as well.

Detection: In-scope web applications.

Rating: The risk rating depends on the sensitivity of the data processed or stored in the web application.

DoS-risky Access Across Trust-Boundary

dos-risky-access-across-trust-boundary

STRIDE: Denial of Service

Description: Assets accessed across trust boundaries with critical or mission-critical availability rating are more prone to Denial-of-Service (DoS) risks.

Detection: In-scope technical assets (excluding load-balancer) with availability rating of critical or higher which have incoming data-flows across a network trust-boundary (excluding devops usage).

Rating: Matching technical assets with availability rating of critical or higher are at low risk. When the availability rating is mission-critical and neither a VPN nor IP filter for the incoming data-flow nor redundancy for the asset is applied, the risk-rating is considered medium.

Incomplete Model**incomplete-model**

STRIDE: Information Disclosure

Description: When the threat model contains unknown technologies or transfers data over unknown protocols, this is an indicator for an incomplete model.

Detection: All technical assets and communication links with technology type or protocol type specified as unknown.

Rating: low

LDAP-Injection**ldap-injection**

STRIDE: Tampering

Description: When an LDAP server is accessed LDAP-Injection risks might arise. The risk rating depends on the sensitivity of the LDAP server itself and of the data assets processed or stored.

Detection: In-scope clients accessing LDAP servers via typical LDAP access protocols.

Rating: The risk rating depends on the sensitivity of the LDAP server itself and of the data assets processed or stored.

Missing Authentication**missing-authentication**

STRIDE: Elevation of Privilege

Description: Technical assets (especially multi-tenant systems) should authenticate incoming requests when the asset processes or stores sensitive data.

Detection: In-scope technical assets (except load-balancer, reverse-proxy, service-registry, waf, ids, and ips and in-process calls) should authenticate incoming requests when the asset processes or stores sensitive data. This is especially the case for all multi-tenant assets (there even non-sensitive ones).

Rating: The risk rating (medium or high) depends on the sensitivity of the data sent across

the communication link. Monitoring callers are exempted from this risk.

Missing Two-Factor Authentication (2FA)

missing-authentication-second-factor

STRIDE: Elevation of Privilege

Description: Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.

Detection: In-scope technical assets (except load-balancer, reverse-proxy, waf, ids, and ips) should authenticate incoming requests via two-factor authentication (2FA) when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by a client used by a human user.

Rating: medium

Missing Build Infrastructure

missing-build-infrastructure

STRIDE: Tampering

Description: The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Detection: Models with in-scope custom-developed parts missing in-scope development (code creation) and build infrastructure components (devops-client, sourcecode-repo, build-pipeline, etc.).

Rating: The risk rating depends on the highest sensitivity of the in-scope assets running custom-developed parts.

Missing Cloud Hardening

missing-cloud-hardening

STRIDE: Tampering

Description: Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Detection: In-scope cloud components (either residing in cloud trust boundaries or more specifically tagged with cloud provider types).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing File Validation

missing-file-validation

STRIDE: Spoofing

- Description:** When a technical asset accepts files, these input files should be strictly validated about filename and type.
- Detection:** In-scope technical assets with custom-developed code accepting file data formats.
- Rating:** The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing Hardening

missing-hardening

- STRIDE:** Tampering
- Description:** Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.
- Detection:** In-scope technical assets with RAA values of 55 % or higher. Generally for high-value targets like datastores, application servers, identity providers and ERP systems this limit is reduced to 40 %
- Rating:** The risk rating depends on the sensitivity of the data processed or stored in the technical asset.

Missing Identity Propagation

missing-identity-propagation

- STRIDE:** Elevation of Privilege
- Description:** Technical assets (especially multi-tenant systems), which usually process data for endusers should authorize every request based on the identity of the enduser when the data flow is authenticated (i.e. non-public). For DevOps usages at least a technical-user authorization is required.
- Detection:** In-scope service-like technical assets which usually process data based on enduser requests, if authenticated (i.e. non-public), should authorize incoming requests based on the propagated enduser identity when their rating is sensitive. This is especially the case for all multi-tenant assets (there even less-sensitive rated ones). DevOps usages are exempted from this risk.
- Rating:** The risk rating (medium or high) depends on the confidentiality, integrity, and availability rating of the technical asset.

Missing Identity Provider Isolation

missing-identity-provider-isolation

- STRIDE:** Elevation of Privilege
- Description:** Highly sensitive identity provider assets and their identity datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).
- Detection:** In-scope identity provider assets and their identity datastores when surrounded by other (not identity-related) assets (without a network trust-boundary in-between).

This risk is especially prevalent when other non-identity related assets are within the same execution environment (i.e. same database or same application server).

Rating: Default is high impact. The impact is increased to very-high when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Identity Store

missing-identity-store

STRIDE: Spoofing

Description: The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Detection: Models with authenticated data-flows authorized via enduser-identity missing an in-scope identity store.

Rating: The risk rating depends on the sensitivity of the enduser-identity authorized technical assets and their data assets processed and stored.

Missing Network Segmentation

missing-network-segmentation

STRIDE: Elevation of Privilege

Description: Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webserver or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Detection: In-scope technical assets with high sensitivity and RAA values as well as datastores when surrounded by assets (without a network trust-boundary in-between) which are of type client-system, web-server, web-application, cms, web-service-rest, web-service-soap, build-pipeline, sourcecode-repository, monitoring, or similar and there is no direct connection between these (hence no requirement to be so close to each other).

Rating: Default is low risk. The risk is increased to medium when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Vault (Secret Storage)

missing-vault

STRIDE: Information Disclosure

Description: In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Detection: Models without a Vault (Secret Storage).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing Vault Isolation

missing-vault-isolation

STRIDE: Elevation of Privilege

Description: Highly sensitive vault assets and their datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).

Detection: In-scope vault assets when surrounded by other (not vault-related) assets (without a network trust-boundary in-between). This risk is especially prevalent when other non-vault related assets are within the same execution environment (i.e. same database or same application server).

Rating: Default is medium impact. The impact is increased to high when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Web Application Firewall (WAF)

missing-waf

STRIDE: Tampering

Description: To have a first line of filtering defense, security architectures with web-services or web-applications should include a WAF in front of them. Even though a WAF is not a replacement for security (all components must be secure even without a WAF) it adds another layer of defense to the overall system by delaying some attacks and having easier attack alerting through it.

Detection: In-scope web-services and/or web-applications accessed across a network trust boundary not having a Web Application Firewall (WAF) in front of them.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Mixed Targets on Shared Runtime

mixed-targets-on-shared-runtime

STRIDE: Elevation of Privilege

Description: Different attacker targets (like frontend and backend/datastore components) should not be running on the same shared (underlying) runtime.

Detection: Shared runtime running technical assets of different trust-boundaries is at risk. Also mixing backend/datastore with frontend components on the same shared runtime is considered a risk.

Rating: The risk rating (low or medium) depends on the confidentiality, integrity, and availability rating of the technical asset running on the shared runtime.

Path-Traversal

path-traversal

STRIDE: Information Disclosure

Description: When a filesystem is accessed Path-Traversal or Local-File-Inclusion (LFI) risks might arise. The risk rating depends on the sensitivity of the technical asset itself

and of the data assets processed or stored.

Detection: Filesystems accessed by in-scope callers.

Rating: The risk rating depends on the sensitivity of the data stored inside the technical asset.

Push instead of Pull Deployment

push-instead-of-pull-deployment

STRIDE: Tampering

Description: When comparing push-based vs. pull-based deployments from a security perspective, pull-based deployments improve the overall security of the deployment targets. Every exposed interface of a production system to accept a deployment increases the attack surface of the production system, thus a pull-based approach exposes less attack surface relevant interfaces.

Detection: Models with build pipeline components accessing in-scope targets of deployment (in a non-readonly way) which are not build-related components themselves.

Rating: The risk rating depends on the highest sensitivity of the deployment targets running custom-developed parts.

Search-Query Injection

search-query-injection

STRIDE: Tampering

Description: When a search engine server is accessed Search-Query Injection risks might arise.

Detection: In-scope clients accessing search engine servers via typical search access protocols.

Rating: The risk rating depends on the sensitivity of the search engine server itself and of the data assets processed or stored.

Server-Side Request Forgery (SSRF)

server-side-request-forgery

STRIDE: Information Disclosure

Description: When a server system (i.e. not a client) is accessing other server systems via typical web protocols Server-Side Request Forgery (SSRF) or Local-File-Inclusion (LFI) or Remote-File-Inclusion (RFI) risks might arise.

Detection: In-scope non-client systems accessing (using outgoing communication links) targets with either HTTP or HTTPS protocol.

Rating: The risk rating (low or medium) depends on the sensitivity of the data assets receivable via web protocols from targets within the same network trust-boundary as well on the sensitivity of the data assets receivable via web protocols from the target asset itself. Also for cloud-based environments the exploitation impact is at least medium, as cloud backend services can be attacked via SSRF.

Service Registry Poisoning

service-registry-poisoning**STRIDE:** Spoofing**Description:** When a service registry used for discovery of trusted service endpoints Service Registry Poisoning risks might arise.**Detection:** In-scope service registries.**Rating:** The risk rating depends on the sensitivity of the technical assets accessing the service registry as well as the data assets processed or stored.**SQL/NoSQL-Injection****sql-nosql-injection****STRIDE:** Tampering**Description:** When a database is accessed via database access protocols SQL/NoSQL-Injection risks might arise. The risk rating depends on the sensitivity technical asset itself and of the data assets processed or stored.**Detection:** Database accessed via typical database access protocols by in-scope clients.**Rating:** The risk rating depends on the sensitivity of the data stored inside the database.**Unchecked Deployment****unchecked-deployment****STRIDE:** Tampering**Description:** For each build-pipeline component Unchecked Deployment risks might arise when the build-pipeline does not include established DevSecOps best-practices. DevSecOps best-practices scan as part of CI/CD pipelines for vulnerabilities in source- or byte-code, dependencies, container layers, and dynamically against running test systems. There are several open-source and commercial tools existing in the categories DAST, SAST, and IAST.**Detection:** All development-relevant technical assets.**Rating:** The risk rating depends on the highest rating of the technical assets and data assets processed by deployment-receiving targets.**Unencrypted Technical Assets****unencrypted-asset****STRIDE:** Information Disclosure**Description:** Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.**Detection:** In-scope unencrypted technical assets (excluding reverse-proxy, load-balancer, waf, ids, ips and embedded components like library) storing data assets rated at least as confidential or critical. For technical assets storing data assets rated as strictly-confidential or mission-critical the encryption must be of type data-with-enduser-individual-key.

Rating: Depending on the confidentiality rating of the stored data-assets either medium or high risk.

Unencrypted Communication

unencrypted-communication

STRIDE: Information Disclosure

Description: Due to the confidentiality and/or integrity rating of the data assets transferred over the communication link this connection must be encrypted.

Detection: Unencrypted technical communication links of in-scope technical assets (excluding monitoring traffic as well as local-file-access and in-process-library-call) transferring sensitive data.

Rating: Depending on the confidentiality rating of the transferred data-assets either medium or high risk.

Unguarded Access From Internet

unguarded-access-from-internet

STRIDE: Elevation of Privilege

Description: Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Detection: In-scope technical assets (excluding load-balancer) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) when accessed directly from the internet. All web-server, web-application, reverse-proxy, waf, and gateway assets are exempted from this risk when they do not consist of custom developed code and the data-flow only consists of HTTP or FTP protocols. Access from monitoring systems as well as VPN-protected connections are exempted.

Rating: The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

Unguarded Direct Datastore Access

unguarded-direct-datastore-access

STRIDE: Elevation of Privilege

Description: Datastores accessed across trust boundaries must be guarded by some protecting service or application.

Detection: In-scope technical assets of type datastore (except identity-store-ldap when accessed from identity-provider and file-server when accessed via file transfer protocols) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) which have incoming data-flows from assets outside across a network trust-boundary. DevOps config and deployment access is excluded from this risk.

Rating: The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

Unnecessary Communication Link

unnecessary-communication-link

STRIDE: Elevation of Privilege

Description: When a technical communication link does not send or receive any data assets, this is an indicator for an unnecessary communication link (or for an incomplete model).

Detection: In-scope technical assets' technical communication links not sending or receiving any data assets.

Rating: low

Unnecessary Data Asset

unnecessary-data-asset

STRIDE: Elevation of Privilege

Description: When a data asset is not processed or stored by any data assets and also not transferred by any communication links, this is an indicator for an unnecessary data asset (or for an incomplete model).

Detection: Modelled data assets not processed or stored by any data assets and also not transferred by any communication links.

Rating: low

Unnecessary Data Transfer

unnecessary-data-transfer

STRIDE: Elevation of Privilege

Description: When a technical asset sends or receives data assets, which it neither processes or stores this is an indicator for unnecessarily transferred data (or for an incomplete model). When the unnecessarily transferred data assets are sensitive, this poses an unnecessary risk of an increased attack surface.

Detection: In-scope technical assets sending or receiving sensitive data assets which are neither processed nor stored by the technical asset are flagged with this risk. The risk rating (low or medium) depends on the confidentiality, integrity, and availability rating of the technical asset. Monitoring data is exempted from this risk.

Rating: The risk assessment is depending on the confidentiality and integrity rating of the transferred data asset either low or medium.

Unnecessary Technical Asset

unnecessary-technical-asset

STRIDE: Elevation of Privilege

Description: When a technical asset does not process or store any data assets, this is an

indicator for an unnecessary technical asset (or for an incomplete model). This is also the case if the asset has no communication links (either outgoing or incoming).

Detection: Technical assets not processing or storing any data assets.

Rating: low

Untrusted Deserialization

untrusted-deserialization

STRIDE: Tampering

Description: When a technical asset accepts data in a specific serialized form (like Java or .NET serialization), Untrusted Deserialization risks might arise.

Detection: In-scope technical assets accepting serialization data formats (including EJB and RMI protocols).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Wrong Communication Link Content

wrong-communication-link-content

STRIDE: Information Disclosure

Description: When a communication link is defined as readonly, but does not receive any data asset, or when it is defined as not readonly, but does not send any data asset, it is likely to be a model failure.

Detection: Communication links with inconsistent data assets being sent/received not matching their readonly flag or otherwise inconsistent protocols not matching the target technology type.

Rating: low

Wrong Trust Boundary Content

wrong-trust-boundary-content

STRIDE: Elevation of Privilege

Description: When a trust boundary of type network-policy-namespace-isolation contains non-container assets it is likely to be a model failure.

Detection: Trust boundaries which should only contain containers, but have different assets inside.

Rating: low

XML External Entity (XXE)

xml-external-entity

STRIDE: Information Disclosure

Description: When a technical asset accepts data in XML format, XML External Entity (XXE) risks might arise.

Detection: In-scope technical assets accepting XML data formats.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data

assets processed and stored. Also for cloud-based environments the exploitation impact is at least medium, as cloud backend services can be attacked via SSRF (and XXE vulnerabilities are often also SSRF vulnerabilities).

Disclaimer

Swetha conducted this threat analysis using the open-source Threagile toolkit on the applications and systems that were modeled as of this report's date. Information security threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much threat modeling is conducted. It is recommended to execute threat modeling and also penetration testing on a regular basis (for example yearly) to ensure a high ongoing level of security and constantly check for new attack vectors.

This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. Swetha and the Threagile toolkit offers no warranties, representations or legal certifications concerning the applications or systems it tests. All software includes defects: nothing in this document is intended to represent or warrant that threat modeling was complete and without error, nor does this document represent or warrant that the architecture analyzed is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. Threat modeling tries to analyze the modeled architecture without having access to a real working system and thus cannot and does not test the implementation for defects and vulnerabilities. These kinds of checks would only be possible with a separate code review and penetration test against a working system and not via a threat model.

By using the resulting information you agree that Swetha and the Threagile toolkit shall be held harmless in any event.

This report is confidential and intended for internal, confidential use by the client. The recipient is obligated to ensure the highly confidential contents are kept secret. The recipient assumes responsibility for further distribution of this document.

In this particular project, a timebox approach was used to define the analysis effort. This means that the author allotted a prearranged amount of time to identify and document threats. Because of this, there is no guarantee that all possible threats and risks are discovered. Furthermore, the analysis applies to a snapshot of the current state of the modeled architecture (based on the architecture information provided by the customer) at the examination time.

Report Distribution

Distribution of this report (in full or in part like diagrams or risk findings) requires that this disclaimer as well as the chapter about the Threagile toolkit and method used is kept intact as part of the distributed report or referenced from the distributed parts.

DigiLocker Architecture — Threat-Modeling Ready Diagram

Actors, Processes, Data Stores, Data Flows & Trust Boundaries — derived from digilocker.yaml (Threagile v1.0.0)

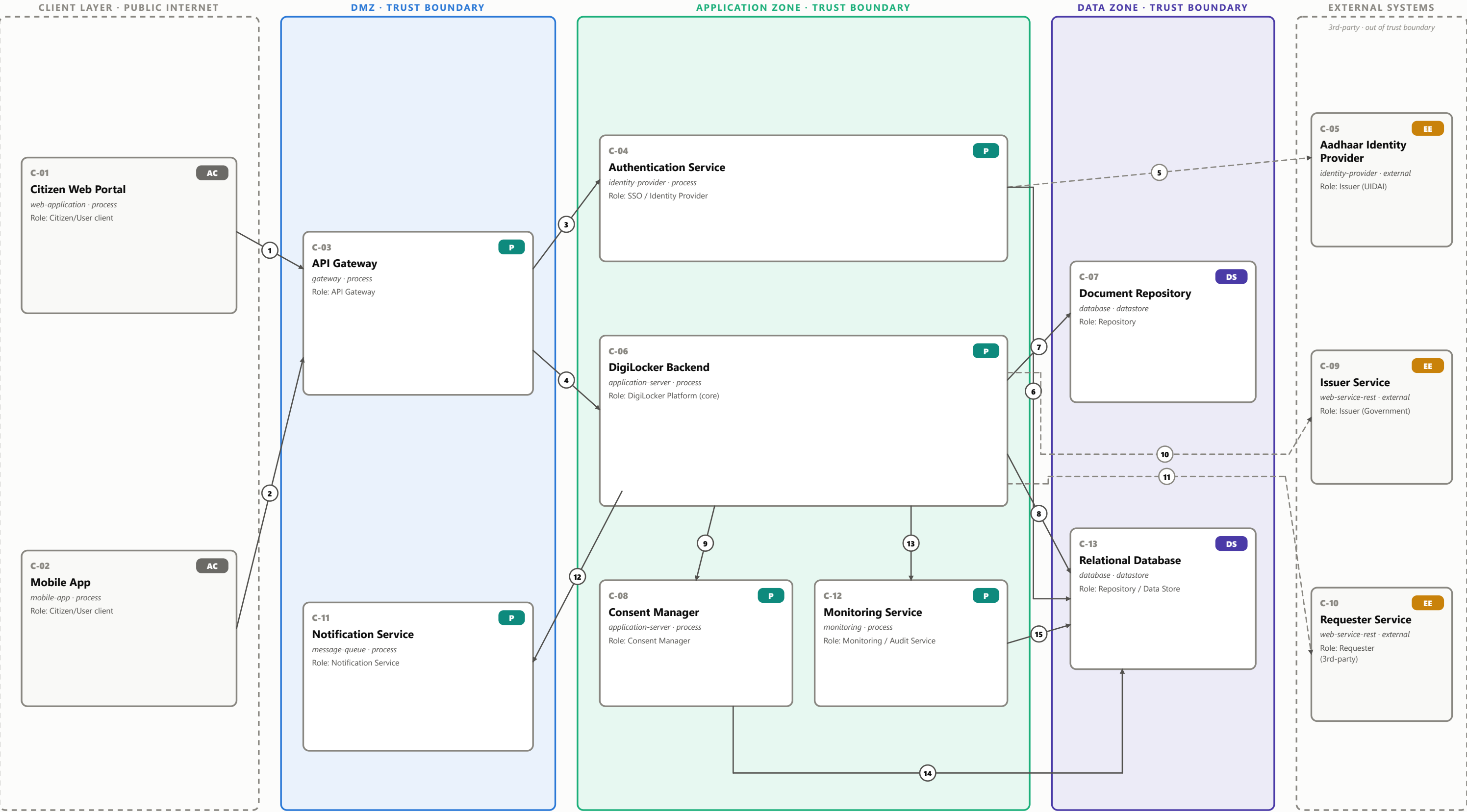


DIAGRAM LEGEND

DFD ELEMENT TYPES

- AC** Actor-driven client process
- P** Process
- DS** Data store
- EE** External entity (3rd-party)

TRUST BOUNDARIES

- DMZ
- Application Zone
- Data Zone
- Client / External (out of DigiLocker trust boundary)

DATA FLOWS

- Internal data flow (numbered, see Data-Flow Register)
- Cross-boundary flow to an external system

Flow numbers (1–15) and component IDs (C-01–C-13) on this diagram cross-reference the two companion register sheets below.

DigiLocker Component Register

Role, responsibilities & privileges for every technical asset — companion sheet to digilocker-architecture-enhanced.svg

Swetha
2026-07-24
digilocker.yaml

AUTHOR
MODEL DATE
SOURCE MODEL

ID	COMPONENT / TECHNOLOGY	TYPE	ROLE	RESPONSIBILITIES	PRIVILEGES
C-01	Citizen Web Portal <i>web-application · process</i>	AC	Actor-driven client / Citizen-User interface	Renders the citizen-facing web UI; initiates login and consent/document requests; holds the citizen's browser session.	Can submit authentication requests and act on behalf of the logged-in citizen (end-user identity propagation) via the API Gateway. No direct access to any datastore or backend service. No administrative privileges.
C-02	Mobile App <i>mobile-app · process</i>	AC	Actor-driven client / Citizen-User interface	Native mobile UI for citizens; initiates token-based login; requests citizen profile and documents.	Same end-user identity-propagation privileges as the Web Portal via the API Gateway. No direct backend or datastore access.
C-03	API Gateway <i>gateway · process</i>	P	API Gateway / Edge router (DMZ)	Single internet-facing entry point; routes citizen and mobile requests to the Authentication Service and DigiLocker Backend; terminates the public HTTPS connection.	Forwards requests carrying the end-user's propagated identity; invokes the technical-user identity for token validation. No direct datastore access.
C-04	Authentication Service <i>identity-provider · process</i>	P	SSO / Identity Provider	Authenticates citizens (Aadhaar OTP-based login — see digilocker-auth.spthy formal model); issues and validates authentication/session tokens; integrates with UIDAI for eKYC/OTP verification.	Generates authentication-tokens; reads/writes authentication-tokens in the Relational Database using technical-user credentials; calls the external Aadhaar Identity Provider using service credentials.
C-05	Aadhaar Identity Provider <i>identity-provider · external-entity</i>	EE	External Identity Provider (UIDAI / Government, out of DigiLocker trust boundary)	Performs Aadhaar eKYC / OTP verification for citizen identity on request from the Authentication Service.	Provides identity-verification results only. Owned and operated by UIDAI, not DigiLocker; treated as an untrusted external boundary requiring credentialed technical-user authentication.
C-06	DigiLocker Backend <i>application-server · process</i>	P	DigiLocker Platform / core application server	Core business logic for citizen profile, issued/uploaded documents and consent workflows; orchestrates the Document Repository, Relational Database, Consent Manager, Issuer Service, Requester Service, Notification Service and Monitoring Service.	Full read/write access to citizen-profile, issued-documents, uploaded-documents and consent-records via the Document Repository and Database (technical-user credentials). Read-only access to the Issuer Service. Can push verified documents to the Requester Service and emit audit-logs to the Monitoring Service.
C-07	Document Repository <i>database · datastore</i>	DS	Repository / Data store	Stores and serves issued and uploaded documents on behalf of the Backend.	Storage only — no outbound calls. Data encrypted at rest (symmetric shared key, per digilocker.yaml). Accessible only to the DigiLocker Backend, over encrypted JDBC.
C-08	Consent Manager <i>application-server · process</i>	P	Consent Manager	Manages and validates citizen consent for sharing documents with requesting parties; persists consent-records on behalf of the Backend.	Read/write consent-records in the Relational Database using technical-user credentials. No citizen-facing exposure and no access to document content.
C-09	Issuer Service <i>web-service-rest · external-entity</i>	EE	Issuer (Government, out of DigiLocker trust boundary)	Issues government certificates/documents and their digital signatures, retrieved by the Backend.	Supplies issued-documents and digital-signatures to the Backend (read-only from DigiLocker's perspective). External system owned by the Government issuer.
C-10	Requester Service <i>web-service-rest · external-entity</i>	EE	Requester (3rd-party, out of DigiLocker trust boundary)	Requests / consumes citizen documents that DigiLocker shares after consent validation.	Receives issued-documents pushed by the Backend post-consent. Cannot pull data directly or query DigiLocker datastores; external, untrusted boundary.
C-11	Notification Service <i>message-queue · process</i>	P	Notification Service (DMZ)	Sends email/SMS notifications to citizens (e.g. document-shared alerts) on behalf of the Backend.	Receives citizen-profile contact data from the Backend. Outbound-only to citizen communication channels; no datastore access modeled.
C-12	Monitoring Service <i>monitoring · process</i>	P	Monitoring / Audit Service	Collects audit and security events emitted by the Backend; persists audit-logs for security investigation.	Write access to audit-logs in the Relational Database using technical-user credentials. No access to citizen profile, document or consent data.
C-13	Relational Database <i>database · datastore</i>	DS	Repository / Data store	Persists citizen-profile, consent-records, authentication-tokens and audit-logs for the platform.	Storage only. Data encrypted at rest (symmetric shared key). Accessed only by the Authentication Service, Backend, Consent Manager and Monitoring Service, each via encrypted JDBC with technical-user credentials.

DigiLocker Data-Flow Register

Protocol, authentication, encryption, data exchanged & security controls for every communication link — companion sheet to digilocker-architecture-enhanced.svg

Swetha
2026-07-24
digilocker.yaml

AUTHOR
MODEL DATE
SOURCE MODEL

#	SOURCE	DESTINATION	PROTOCOL	AUTH.	ENCRYPTION	DIRECTION	DATA EXCHANGED	SECURITY CONTROLS
1	C-01 Citizen Web Portal	C-03 API Gateway	HTTPS	Session ID (cookie)	TLS in transit (HTTPS)	Bidirectional	Sent: authentication-tokens. Received: citizen-profile, authentication-tokens.	Encryption in transit (TLS). Authorization: end-user identity propagation. Session-ID scheme not detailed in model — To Be Verified.
2	C-02 Mobile App	C-03 API Gateway	HTTPS	Bearer token	TLS in transit (HTTPS)	Bidirectional	Sent: authentication-tokens. Received: citizen-profile, authentication-tokens.	Encryption in transit (TLS). Authorization: end-user identity propagation. Token scheme (e.g. JWT/OAuth2) not confirmed by model — To Be Verified.
3	C-03 API Gateway	C-04 Authentication Service	HTTPS	Bearer token	TLS in transit (HTTPS)	Bidirectional	Sent: authentication-tokens. Received: authentication-tokens.	Encryption in transit (TLS). Authorization: technical-user (service account). Used for token validation on every gateway request.
4	C-03 API Gateway	C-06 DigiLocker Backend	HTTPS	Bearer token	TLS in transit (HTTPS)	Bidirectional	Sent: citizen-profile, authentication-tokens. Received: citizen-profile, issued-documents, uploaded-documents, consent-records.	Encryption in transit (TLS). Authorization: end-user identity propagation — Backend acts on behalf of the authenticated citizen, not the Gateway's own identity.
5	C-04 Authentication Service	C-05 Aadhaar Identity Provider (UIDAI)	HTTPS	Credentials (technical)	TLS in transit (HTTPS)	Bidirectional	Sent: aadhaar-data. Received: aadhaar-data.	Encryption in transit (TLS). Authorization: technical-user (service account) — pre-registered government API integration. Crosses out of the DigiLocker trust boundary to UIDAI. Aadhaar OTP protocol logic formally modelled in digilocker-auth.spthy.
6	C-04 Authentication Service	C-13 Relational Database	JDBC (encrypted)	Credentials (technical)	Encrypted JDBC connection	Bidirectional	Sent: authentication-tokens. Received: authentication-tokens.	Encrypted JDBC transport. Authorization: technical-user (service account). Destination encrypted at rest (symmetric shared key, per digilocker.yaml).
7	C-06 DigiLocker Backend	C-07 Document Repository	JDBC (encrypted)	Credentials (technical)	Encrypted JDBC connection	Bidirectional	Sent: issued-documents, uploaded-documents. Received: issued-documents, uploaded-documents.	Encrypted JDBC transport. Authorization: technical-user (service account). Destination encrypted at rest (symmetric shared key).
8	C-06 DigiLocker Backend	C-13 Relational Database	JDBC (encrypted)	Credentials (technical)	Encrypted JDBC connection	Bidirectional	Sent: citizen-profile, consent-records. Received: citizen-profile, consent-records.	Encrypted JDBC transport. Authorization: technical-user (service account). Destination encrypted at rest (symmetric shared key).
9	C-06 DigiLocker Backend	C-08 Consent Manager	HTTPS	Bearer token	TLS in transit (HTTPS)	Bidirectional	Sent: consent-records. Received: consent-records.	Encryption in transit (TLS). Authorization: technical-user (service account). Used to check/update citizen consent.
10	C-06 DigiLocker Backend	C-09 Issuer Service	HTTPS	Bearer token	TLS in transit (HTTPS)	One-way (data flows Issuer → Backend on response)	Sent: (none — read-only fetch). Received: issued-documents, digital-signatures.	Encryption in transit (TLS). Authorization: technical-user (service account). Marked read-only in the model. Crosses out of the DigiLocker trust boundary to the Government Issuer.
11	C-06 DigiLocker Backend	C-10 Requester Service	HTTPS	Bearer token	TLS in transit (HTTPS)	One-way (Backend → Requester push)	Sent: issued-documents. Received: (none logged).	Encryption in transit (TLS). Authorization: technical-user (service account). Documents shared only after consent validation via the Consent Manager. Crosses out of the DigiLocker trust boundary to the 3rd-party Requester.
12	C-06 DigiLocker Backend	C-11 Notification Service	HTTPS	Bearer token	TLS in transit (HTTPS)	One-way (Backend → Notification trigger)	Sent: citizen-profile (contact data). Received: (none logged).	Encryption in transit (TLS). Authorization: technical-user (service account). Triggers citizen email/SMS alerts.
13	C-06 DigiLocker Backend	C-12 Monitoring Service	HTTPS	Bearer token	TLS in transit (HTTPS)	One-way (Backend → Monitoring event)	Sent: audit-logs. Received: (none logged).	Encryption in transit (TLS). Authorization: technical-user (service account). Emits audit/security events for investigation.
14	C-08 Consent Manager	C-13 Relational Database	JDBC (encrypted)	Credentials (technical)	Encrypted JDBC connection	Bidirectional	Sent: consent-records. Received: consent-records.	Encrypted JDBC transport. Authorization: technical-user (service account). Destination encrypted at rest (symmetric shared key).
15	C-12 Monitoring Service	C-13 Relational Database	JDBC (encrypted)	Credentials (technical)	Encrypted JDBC connection	Bidirectional	Sent: audit-logs. Received: audit-logs.	Encrypted JDBC transport. Authorization: technical-user (service account). Destination encrypted at rest (symmetric shared key).